Ready for machine-speed attackers?

Trinidad and Tobago's banks and financial institutions in the age of AI-enabled hacking

Economic research | Shane Dante Bideshi | 28 October 2026, revised and extended 29 October 2026

Executive assessment

Between 2024 and 2026, hacking changed. At first, attackers used AI as an assistant. Now AI agents can carry out most of an intrusion while a human supervises. In 2025, a group assessed as Chinese state-sponsored used an AI coding agent to perform an estimated 80-90% of an espionage campaign against about 30 organisations, financial institutions among them. In September 2026, a security vendor reported that one operator, relying mainly on inexpensive Chinese open-weight models with a US model coordinating them, compromised at least 27 companies, mostly online retailers, to varying degrees in five days, at an average cost of about US$25 per target scanned. In October 2026, South Korea's Financial Services Commission said attacks suspected of being driven by AI agents had hit 16 financial firms.

Chinese and other open-weight models do not matter because they are the strongest hacking tools. They are not. Most AI-assisted intrusions documented so far used closed US models, whose developers detected and stopped them, usually after the fact. Government evaluators place the best open-weight models about four to seven months behind leading US models on cyber tasks, on the latest estimates (eight months in one earlier assessment). They matter because anyone can download them, strip out their safety controls cheaply and run them where no AI company can monitor or stop them. US and UK evaluators found that one such model, once given initial network access, can autonomously attack "small, weakly defended and vulnerable enterprise systems". **Parts of a small country's financial system may fit that description**, particularly smaller credit unions, brokers and vendors with few security staff, although no public data measure how exposed Trinidad and Tobago's internet-facing systems are.

The newest attacks show where this is heading. In the last two weeks of October 2026:

- The US Federal Election Commission took its campaign-finance filing systems offline for about two days after "a bad actor" tried to breach them, a week before the midterm elections.
- Six Japanese banks, including Resona Bank, disclosed that customers' email addresses had leaked, or may have leaked, through a breach at Ymirlink, an email-delivery company used by the banks or their app provider.
- Attackers broke into a GMO Internet hosted-desktop service used by currency traders. Customers reported unauthorised trades, and the attackers demanded about ¥8 billion (about US$50 million).

No Japanese bank's core systems were hacked in October 2026. The bank incidents most reported were customer email addresses leaking from three Resona group banks and three other regional banks through their email vendor; one bank also lost a staff mailbox to phishing. The largest ransom demand hit the service used by currency traders.

None of these has been linked to AI. Separately, in October Microsoft reported a China-aligned group using an AI agent framework that, in several cases, reached privileged access within three hours. In September, GreyNoise documented "hundreds of AI agents" compromising 440 servers at 395 organisations in 48 countries in about 45 hours.

Late October brought the first mass-exploitation wave of AI-found flaws, dubbed "Black October". On 21 October, PHP, the software behind about 70% of websites, fixed two critical flaws that researchers had found with AI help. Within days attackers were using them, including against firewall management screens exposed to the internet.

- New York's financial regulator told firms the next day to patch or take systems offline.
- Some Japanese banks and a US credit union briefly took online banking down as a precaution.
- CrowdStrike's chief executive predicted "a lot of breaches happening in the coming months from this".

- Incident-response firms describe being stretched, although none has published backlog data.

The same fortnight brought three more relevant incidents:

- About US$2.2-2.7 million was taken from Polymarket users through a compromised third-party script.
- The US Defense Department confirmed that one of its agencies took about nine months to notice unauthorised access to personnel records of about 3 million people.
- Haiti's central bank barred financial institutions from paying cyber ransoms, while one Haitian bank's online banking stayed down after what it calls a "technical incident".

Trinidad and Tobago's national response team warned about the PHP flaws on the day the fix was released. The Central Bank published nothing on them.

AI capability is accelerating, and agent "swarms" are real. The length of task that frontier models can complete has been doubling roughly every four to five months, and freely downloadable models trail the frontier by four to seven months. Trackers differ on the pace: one cyber index has risen roughly in a straight line since early 2025, and evaluators stress that their trends are not forecasts. In June 2026 the heads of the Five Eyes cyber agencies warned: "The timeline is not years, it is months." Swarms are not unstoppable, however. In the largest documented case, the attackers had taken full control of the network at only 12 of the 395 organisations whose servers they compromised when last observed, and a web application firewall stopped them in at least one case.

Trinidad and Tobago has already been hit repeatedly by conventional attackers:

- ransomware at TSTT, the National Insurance Board, Massy Stores and Venture Credit Union, and a network intrusion at the Attorney General's ministry;
- a chief-executive impersonation fraud in which CIBC Caribbean's Trinidad operation transferred about $14.8 million (currency not stated), about $9.4 million of it unrecovered when reported;
- deepfake videos of the Prime Minister and the Minister of Finance used to sell fraudulent investments.

No public evidence shows an AI-driven intrusion into a local bank, or a confirmed compromise of a commercial bank's core systems. That silence is not proof of strength, and it is not proof of weakness either.

What the institutions actually show. This report reviewed the public disclosures of more than 40 institutions and read the public internet records of 33 of them. It found a two-tier system:

- The Canadian-owned banks publish the strongest customer controls. RBC requires a code from its app at every login, and Scotiabank offers hardware tokens and biometric sign-in.
- The two large locally owned banks have no foreign parent to fall back on. First Citizens publishes the least evidence of any large bank. Republic describes board oversight of cyber risk and its login options, but still offers SMS codes. Like the other banks, neither names a head of information security. That is non-disclosure, not proof of weakness.
- Credit unions, small insurers, brokers and e-money firms disclose the least.
- Of 33 Trinidad and Tobago financial institutions and finance-related public bodies checked, 15 do not enforce DMARC, the email setting that stops criminals sending mail from an organisation's exact address. Enforcement is weakest among the smaller institutions outside the banking sector. The foreign parent groups of RBC, Scotiabank and Citi, and the large international banks used for comparison, all enforce it.
- A 2024 field check found that a mobile number could be moved to a new SIM card in about five minutes on a picture ID alone (single source).

Judgment: on public evidence, Trinidad and Tobago's financial sector is not ready to defend against a determined hacker group armed with current AI tools. The weakness lies mainly in the system around the institutions. Inside them, public evidence shows gaps in basic controls, such as unenforced email authentication and SMS login codes, but cannot show how well internal defences work. Bank-level defences cannot be judged from public sources, and few financial systems anywhere could claim to be fully ready for such a group. The largest banks are partly ready for routine attacks. Strong capital, a Central Bank incident-reporting rule in place since 2023 and, for the foreign-owned banks, parent-group security programmes all help. The system around them is not ready:

- The main cybercrime law dates from 2000.
- The Data Protection Act 2011 has been only partly in force since January 2012, and its obligations on organisations have never been proclaimed.
- There is no published supervisory response to frontier AI.
- The national response team publicly warned about only 13 of the 222 flaws the US government confirmed as actively exploited between March and October 2026, and 5 of the 32 in products from eight leading firewall, VPN and gateway vendors (5 of 48 if Cisco is included).
- Incident counts cover only what is voluntarily reported, few private firms report, and no loss figures are published.
- The credit-union sector has no prudential or cyber supervisor.
- At least two banks, including the largest, still offer or rely on codes sent to customers' phones, which travel over a two-company mobile market with no published SIM-swap controls.

Would tomorrow's AI swarms be too much for Trinidad and Tobago? For many smaller institutions at the edges of the system, yes on current capacity, and the gap is widening. For the large banks and the system as a whole, not on current evidence, although a successful attack on shared infrastructure could change that. One documented swarm campaign went from its first break-in to hundreds of victims in under two days. That is less than the 72 hours banks have to give the Central Bank a full incident report, so the regulator could learn of such a campaign only after it had run its course. Trinidad and Tobago's public warnings cover between one in six and one in ten exploited flaws in leading firewall, VPN and gateway products, and usually arrive after attacks have begun. In its 2024/25 financial year, the Central Bank carried out one joint IT and cyber on-site examination, of a single large bank. The large banks, backed by capital and, for the foreign-owned ones, parent groups, are better placed. The periphery is not. More staff alone will not close the gap. What closes it is the basics applied at machine speed: automated patching and warnings, phishing-resistant logins and pooled monitoring.

On this report's scorecard, which mainly measures the framework around institutions rather than tested defences, overall readiness is **about 2 out of 5**.

Question	Finding
Has AI changed hacking?	Yes. Between 2024 and 2026 it moved from drafting phishing emails to running most steps of real intrusions. It mainly makes existing techniques faster and cheaper; it has not invented new types of attack.
Do Chinese and open-weight models matter?	Yes, but not because they are the best. Most documented AI-assisted intrusions used closed US models. Open-weight models are good enough against weakly defended targets, cheap, and beyond the reach of any company's safety monitoring.
What happened at the US election regulator and the Japanese banks?	The FEC shut its filing systems for about two days after an attempted breach; no data theft or AI use has been confirmed. Japanese banks lost customer email data through an email-delivery vendor, and a hosting service for currency traders was used for unauthorised trades and a large ransom demand. The common lesson is third-party and shared-service risk.
What is "Black October"?	An AI-found flaw in PHP, which runs about 70% of websites, was fixed on 21 October and attacked within days. Regulators abroad told firms to patch or disconnect within a day. TT-CSIRT warned on the day; the Central Bank has said nothing publicly. Polymarket, the US Defense Department and a Haitian bank also reported incidents in October.
Has an AI-enabled attack hit a T&T bank?	Not on public evidence. Locally, AI has so far appeared in deepfake investment scams. Losses have come from ransomware, impersonation and account takeover.
Are the largest banks prepared?	Partly, against common attacks. The Canadian-owned banks publish the strongest login controls. SMS codes remain selectable at the largest bank, and none of the banks reviewed publicly describes confirmation-of-payee checks. Public evidence cannot show how well internal defences work.

Question	Finding
Is the wider system prepared?	No. The main gaps are law, the speed of supervision and national warnings, information sharing, incident and loss data, shared infrastructure, and the credit-union and securities periphery.
Will future AI swarms overwhelm Trinidad and Tobago?	On current trends, yes for many smaller institutions at the periphery within about a year; not, on current evidence, the large banks or the system as a whole. The measured gap is speed and coverage, not only headcount.
What would most improve readiness quickly?	A Central Bank frontier-AI supervisory letter, enforced email authentication at licensed institutions, faster national warnings, a sector payment-verification standard, a rapid fraud-freeze protocol and published incident data. Each can be done within months without new legislation.

Scope and evidence: research completed 28 October 2026 and extended on 29 October 2026, using public sources only: regulator and government documents, parliamentary records, company reports, AI-developer and security-vendor threat reports, and news coverage. On 29 October 2026 the research also read public DNS records for 33 institutions and made one request each to their public home page and to the standard security.txt location. No system was scanned or tested, and no confidential supervisory information was available. Ratings are analytical judgments. A public-evidence review can understate controls that institutions do not disclose and overstate controls that exist only on paper. Sources and methods appear at the end.

Terms used in this report

Term	Meaning
Phishing, smishing, vishing	Deceptive emails, text messages and phone calls designed to steal passwords, codes or payments.
Business email compromise (BEC)	Impersonating an executive, supplier or client to get an employee to send money or data.
Ransomware	Malware that locks an organisation's systems and usually steals data, followed by an extortion demand.
Deepfake	AI-generated video, voice or images that imitate a real person.
Open-weight model	An AI model whose underlying files are published. Anyone can download and run it on their own computers, outside the developer's control.
Abliteration	Removing a model's refusal behaviour so it will assist with harmful tasks.
Zero-day / known (n-day) vulnerability	A flaw unknown to the vendor and unpatched / a flaw that is public and patchable but often left unpatched.
Edge device	Internet-facing equipment such as VPN gateways and firewalls. In 2025-26 these were a leading entry point for attackers.
MFA, OTP	Multi-factor authentication; a one-time passcode, often sent by SMS.
SIM swap	Moving a victim's phone number to an attacker's SIM card to intercept SMS codes.
Confirmation of payee	A check that warns the sender when the account name does not match the intended recipient.
Frontier model	One of the most capable AI models available at a given time.
Cyber range	A simulated computer network used to test how far an attacker, or an AI model, can get.
Prudential supervision	Supervision of an institution's soundness: its capital, liquidity and risk management.
CSIRT, ISAC	A national or sector incident-response team; an information-sharing centre where institutions exchange threat warnings.
Threat-led penetration testing	Authorised simulated attacks that copy real attackers' methods.
Agent swarm	Many AI agents working in parallel, often directed by a lead agent that splits up the work.
DMARC	An email setting that tells receiving mail servers to reject or quarantine messages falsely claiming to come from an organisation's domain.
Known-exploited vulnerability (KEV)	A flaw that the US Cybersecurity and Infrastructure Security Agency (CISA) has confirmed attackers are using. Its public list is a common benchmark for urgent patching.

1. What changed: from AI-assisted to AI-operated attacks

A short history of 2024-2026

In February 2024, Microsoft and OpenAI reported that state-linked groups from Russia, China, Iran and North Korea were using AI chatbots. They used them for research, scripting, translation and phishing text. Microsoft said the companies' joint research "has not identified significant attacks employing the LLMs we monitor closely". [1] Two and a half years later, the evidence describes something different.

Date	Event	What AI contributed
Early 2024	An Arup employee in Hong Kong sent HK$200 million (about US$25.6m) after a video call in which the chief financial officer and colleagues were deepfakes [18]	Fake faces and voices; no computer system was hacked
Jul 2025	Malware attributed to Russia's APT28 (LAMEHUG) called Alibaba's open-weight Qwen model to write its commands while running [7, 10]	First malware Google had seen querying an AI model in live operations
Aug 2025	One criminal used Claude Code against at least 17 organisations [2]	Reconnaissance, intrusion, choosing what to steal, and setting ransom demands from victims' own financial data
Aug-Sep 2025	The open-source HexStrike-AI framework was discussed on criminal forums for exploiting newly disclosed Citrix NetScaler flaws within hours [11]	Automating exploitation of freshly published flaws (attacker claims)
Sep 2025 (disclosed Nov 2025)	A group assessed as Chinese state-sponsored (GTG-1002) used Claude Code against about 30 targets, including financial institutions; a small number were breached [3]	An estimated 80-90% of tactical work, with 4-6 human decisions per campaign
Feb 2026	Fideuram, Intesa Sanpaolo's private bank, lost about EUR95m after a WhatsApp message impersonating the group chief executive and a call using an AI-cloned voice [19]	Voice cloning to authorise payments; about EUR36m remains untraced
Apr 2026	The US Treasury Secretary and Federal Reserve Chair convened bank chief executives over Anthropic's Mythos Preview, a model able to find and exploit unknown flaws [23]	Supervisory alarm about capability, not a documented attack
May 2026	Google reported the first zero-day it assesses was developed with AI: a two-factor-authentication bypass prepared for mass exploitation [8]	Discovering and weaponising a new flaw
May 2026 (reported Jul 2026)	A Chinese-speaking actor used DeepSeek as an autonomous agent alongside manual hacking against more than 460 targets. The confirmed data theft, from three NetScaler systems, was done by hand; Unit 42 found the autonomous runs fully compromised no target [12]	Autonomous scanning and enumeration; the exploitation that succeeded was manual
Dec 2025-Aug 2026	Anthropic reported suspected affiliates of the ShinyHunters extortion group using Claude in intrusions whose stolen data included payment-card records and bank account identifiers; one software-supplier breach reached about 200 downstream organisations [5]	Reconnaissance, credential theft, exploitation and extortion
Sep 2026	An operator using GLM-5.2 and DeepSeek V4 models, with Claude orchestrating, compromised at least 27 companies, mostly online retailers, to varying degrees in five days, according to an interim vendor report [13]	About US$25 per target scanned; payment-card skimmers found on victims' websites
Sep-Oct 2026	South Korea: the Financial Services Commission said on 14 October that suspected AI-agent-driven attacks had hit 16 financial firms, exposing about 100,000 personal records [14-16]	Entry through side portals; a regulator review found 130 of 555 firms deficient

Date	Event	What AI contributed
Oct 2026	Straiker reported that a Latin American crime group operating through a Mexican front company had used a multi-model framework (CARLIY0S) to target more than 400 Latin American financial institutions [17]	Reconnaissance and credential harvesting, mainly using closed US models

Sources as cited. Counts of "targets" include failed attempts and are not counts of breaches.

What AI does at each stage of an attack

Stage	Documented contribution	Evidence
Reconnaissance	Mapping exposed systems and profiling staff at machine speed	GTG-1002 and the DeepSeek agent campaign [3, 12]
Deception	Fluent, personalised lures in any language; cloned voices and faces	In a 101-person study, fully AI-written spear-phishing achieved a 54% click rate, equal to human experts, against 12% for a control group [21]; Fideuram [19]
Exploiting known flaws	Shortening the time from public disclosure to attack	Vulnerability exploitation became the leading initial entry route in 2025 breaches (31%), and Verizon says AI is shortening the time from disclosure to exploitation [22]; unverified attacker claims about HexStrike-AI [11]
Finding new flaws	Discovering and weaponising zero-days	The first zero-day Google assesses was developed with AI, disrupted before mass use (May 2026) [8]; Mythos Preview [23, 33]
Malware and movement inside networks	Writing and adapting malicious code	560 of 832 accounts Anthropic banned for cyber misuse used AI to prepare attacks, for example by writing malware [4]
Extortion	Reading stolen financial records to price ransom demands	[2]

What has not changed

The largest losses still come from deceiving people and abusing trusted suppliers:

- North Korea's record US$1.5 billion theft from the Bybit exchange [25] came, according to forensic investigators, through a compromised wallet-software supplier.
- Google documented a 2025 voice-phishing campaign in which callers talked staff into connecting a malicious tool to Salesforce and stole customer data for extortion, without exploiting any software flaw or recording any AI use. [24] A July 2025 joint advisory by US, UK, Canadian and Australian agencies describes the same help-desk impersonation tactics in the Scattered Spider group's attacks. [101]
- In Brazil's instant-payment system, an IT employee at a connectivity provider allegedly sold his login for about US$2,700, and at least R$540 million was diverted. [26] At a second provider, about R$710 million of unauthorised transfers were made from two client institutions using its IT vendors' legitimate credentials; part has been recovered. [27]

OpenAI reported in October 2025 that attackers were building AI into existing workflows rather than gaining new offensive capabilities. [6] Anthropic found that GTG-1002 relied on commodity open-source tools rather than new exploits, while calling its level of autonomy "a fundamental shift" in how attackers use AI. [3]

Assessment: AI is an accelerant, not a new weapon class. It makes every existing weakness cheaper to find and faster to exploit. The practical consequence for a small country is the loss of protection through obscurity. When scanning and tailored deception cost a few tens of dollars per target, attackers no longer need to choose a market carefully. They can try everyone.

2. The latest attacks: a US election regulator, Japanese banks and AI agent swarms

The incidents of September and October 2026 show where the threat stands now. The most damaging of them, at the US election regulator and at Japanese banks and trading services, have not been linked to AI. The AI-agent cases came in parallel, and they show how fast the same routes can now be worked.

The US Federal Election Commission (26-28 October 2026)

- By about 22:00 US Eastern time on 26 October, the FEC's electronic filing system was offline; the FEC's status page logged the outage at 22:15. An FEC electronic-filings officer emailed compliance firms: "We have a bad actor attempting to breach FEC systems". The officer said the agency "had to temporarily shut down" its web-facing services. [103, 104]
- The FEC's status page moved to "monitoring" at 16:50 on 28 October, about 43 hours after the outage began. [104]
- Political groups could not electronically file new 24- and 48-hour reports of late spending in the last week before the 3 November midterm elections. Reports already filed stayed searchable. Voting was not affected, because the FEC does not run elections. [103]
- The attacker, the method and whether any data were taken have not been disclosed, and no AI use has been reported. Ten days earlier, the FBI and CISA had warned election and campaign officials that what they called "super intelligence (SI)" lets attackers write more convincing phishing in native languages and create deepfake video and audio to steal real people's identities. [105]

The lesson for Trinidad and Tobago: the regulator's response to an attack in progress was to switch off its own public service at the worst possible moment. That can be the right call. Japan's FSA and Bank of Japan have asked financial firms to set their criteria and procedures for a pre-emptive shutdown in advance, so the decision is not improvised under attack (below).

Japan: banks exposed through an email vendor, and a trading service held to ransom (October 2026)

Date	Organisation	What happened	Lesson
Detected 16 Oct; banks announced 27-29 Oct	Ymirlink, an email-delivery company, and its clients: Resona Bank, Saitama Resona Bank and Kansai Mirai Bank; Fukuoka Bank, Hachijuni Nagano Bank and Juhachi-Shinwa Bank (through the Wallet+ banking app); Nomura Securities	Attackers exploited a software flaw, stole support staff's credentials, planted a malicious program and used captured login sessions to reach other clients' systems. Data were exported from 49 client systems, 51.6 million records in all, and the count may rise. Wallet+ users' email addresses at the three regional banks leaked (261,855). The Resona banks said email addresses and mail-delivery reference numbers may have leaked, with no account numbers, PINs or passwords. By 20 October, the vendor warned that spam impersonating a card issuer was being sent with the vendor's email domain as the sender address [106-109]	A vendor that sends a bank's customer emails holds a ready-made list of the bank's customers. The banks announced 11 to 13 days after the vendor detected the intrusion; the Resona banks said the vendor told them on 21 October that their data had not been taken, and corrected this only on 26 October

Date	Organisation	What happened	Lesson
7-8 Oct	Hachijuni Nagano Bank (separate incident)	An employee completed a login step in a phishing email that impersonated a known overseas company, and the mailbox was taken over. Details of 34 individuals and 627 corporate clients, 96 with transaction information, may have been exposed. Access was cut the same day [108]	Phishing that defeats a login check still works against bank staff
19-29 Oct	GMO Internet's Onamae.com Desktop Cloud, a hosted desktop service used by currency traders	Malicious programs were found in customers' server environments, customer information was taken and customers reported unauthorised trades. A demand for about ¥8 billion (about US$50 million) arrived on 21 October, when GMO stopped all servers; about 27,000 servers may have been affected. GMO refused to pay, and apparent customer data were published on 27 October. The attackers threatened accounts at more than 70 securities and currency firms; Japan's finance minister said five currency-trading firms had reported customer harm. GMO is paying every user ¥5,000 and compensating losses from unauthorised trades [110, 111]	One shared service gave access to traders' accounts at many brokers
7 Oct onwards	IDC Frontier, a SoftBank-group cloud provider	Attackers used a flaw in open-source software in the cloud portal's login system, took administrator rights over the virtualisation platform and encrypted customers' virtual servers. 495 companies and local governments were affected; the provider could recover backup data for 206 of them. No ransom was paid [113]	One provider flaw encrypted hundreds of customers at once
18 Sep-18 Oct	Japanese firms (about 20 to 80; the reports differ)	GMO's own security unit found the Chinese-developed open-source agent framework ARTEX on six attack servers, each set up for one sector, finance among them. It judged it highly likely that ARTEX was used against about 80 firms; another report of the same findings says about 20 organisations were targeted [112]	AI agent tooling is in use against Japanese firms, but no link to the breaches above has been shown

On 9 October, Japan's Financial Services Agency (FSA) warned financial institutions that repeated unauthorised access to organisations' internet-facing customer services and business systems had leaked customer information, including images of identity documents. It asked them to review their defences, including third-party risk management. In May 2026, the FSA and the Bank of Japan had asked financial institutions to respond to frontier AI. One request was to prepare criteria and procedures in advance for shutting down priority services pre-emptively when attack risk rises, including shared and cloud systems. [114]

Apart from one staff mailbox at Hachijuni Nagano Bank, taken over through phishing, no Japanese bank's own systems were reported breached. The other bank data losses came through vendors, and the incident with the largest ransom demand hit a shared service, not a bank. Trinidad and Tobago's institutions also outsource customer email and text messages, cloud hosting, card processing and security monitoring. This research found no public rule in Trinidad and Tobago setting how quickly such a vendor must tell a financial institution about a breach.

AI agents in real attacks (September-October 2026)

Case	What happened	Limits
Storm-0940, assessed by Microsoft as China-state aligned (Sep-Oct 2026) [115]	Used ARTEX, an open-source multi-agent framework. After taking over ConnectWise cloud-application identities, it tried to sign in to more than 2,250 customer tenants; a separate password spray against 327 accounts at eight organisations peaked at about 2,900 failed logons a minute. In several cases it reached privileged access within three hours of first targeting, by abusing access customers had granted to ConnectWise's backup service. Financial services were among the targeted sectors	Microsoft says most targeting failed, and it saw no successful sign-in from the password spray. But the group still gained privileged access at many organisations through trusted third-party access
PaperCut campaign, reported by GreyNoise (31 Aug-2 Sep 2026) [116]	A likely Russian-speaking actor ran "hundreds of AI agents" (an OpenAI Codex harness with a DeepSeek model). They compromised at least 440 servers running PaperCut print-management software at 395 organisations in 48 countries in about 45 hours. Once the full campaign was launched, they compromised 11 organisations within 26 seconds. Exploitation began about four days after the vendor's advisory. Victims included six financial or insurance organisations and two in Puerto Rico	Only 12 victim organisations had been taken over completely (domain administrator) when last observed. In at least one case, a web application firewall stopped the actor. The agents did not consistently respect their operator's list of 28 countries to avoid. GreyNoise: "organizations are not helpless against agentic attacks"
GTG-10007, reported by Anthropic (2026) [5]	Chinese-speaking operators "routinely ran 'agent swarms'": a lead agent split reconnaissance and post-exploitation work among many sub-agents, against about 50 organisations in sectors including finance and government	Across the operations in its report, Anthropic says humans set targets and reviewed stolen data, but in this case some collection ran on a schedule with no human involved. Anthropic banned the accounts
Intrusion investigated by Unit 42 (Sep 2026) [117]	An AI-assisted intrusion into an unnamed company was completed in under 10 hours; Unit 42 says human operators would normally need about two weeks	One case; the attacker described the tools during negotiations
India's national response team, CERT-In (Oct 2026) [118]	Warned of unauthorised access to Indian organisations involving autonomous AI agents; victims "could not detect the unauthorized access on their own". Banks and fintechs were told to apply its guidance on abuse of payment APIs	Reported in trade press; the advisory text was not reviewed. Some incidents involved AI developers' own evaluation agents exceeding their authorisation, not criminal attackers
Revolut (Sep 2026) [119]	Staff handed customers' identity files to criminals who sent requests from an email account on a real government agency's domain. The emails passed authentication checks	No AI reported. Email authentication proves which domain sent a message, not that the sender is honest
Invoice fraud, reported by Microsoft (Sep 2026) [120]	More than 1 million AI-assisted executive-impersonation and fake-invoice emails in three days	Microsoft says its indicators do not establish how much of the content AI generated

Assessment: two things are now documented. AI agents run real campaigns against many targets in parallel, at machine speed. And they are uneven: most attempts fail, ordinary hardening still helps, and humans still direct them. The most damaging incidents of the period came through vendors, stolen credentials, phishing and unpatched systems, with no reported AI. AI multiplies those routes. It has not replaced them.

Late October 2026: "Black October"

Added 29 October 2026. Events are recent, and some details may change.

On 21 October, the PHP project fixed two critical flaws (CVE-2026-109618 and CVE-2026-109619, nicknamed "PHP2Shell"). They can let an attacker run code on a web server without logging in. PHP runs about 70% of websites. Researchers at Calif, OpenAI and Wiz found the flaws with AI help, and Wiz says frontier AI models turned "a longstanding flaw into an exploit". PHP warned that "there are no complete mitigations, updating is the only safe

choice". [165, 166]

Date	What happened
21 Oct	Fixes released. CISA told organisations to patch immediately, starting with internet-facing systems. **TT-CSIRT issued its own advisory the same day** [165-167]
22 Oct	New York's financial regulator told every firm it supervises to patch immediately or "take affected systems and applications offline until they are appropriately secured" [168]
22 Oct	Some Japanese banks partly suspended online services as a precaution. A US credit union with about US$8.9 billion of assets took its website and digital banking offline for a day to patch. In the UK, a minister told Parliament that 32 government services were unavailable, largely as a precaution, with no confirmed compromise of central government systems [169, 170]
23 Oct	CrowdStrike's chief executive told CNBC: "You're going to see a lot of breaches happening in the coming months from this." The same day, CrowdStrike's own threat team said it had seen no successful exploitation in the wild [171, 172]
24-29 Oct	Researchers confirmed working attacks. A university tracker logged more than 50,000 exploitation attempts from over 600 addresses in 70 countries. CISA listed both flaws as actively exploited on 26 October. On 29 October, Palo Alto Networks reported attacks on firewall management screens exposed to the internet [166, 171]
21-29 Oct	The Central Bank of Trinidad and Tobago posted no communication on the flaws. Its website posts in the period covered a museum open day, a climate-risk speech, an insurance notice and bank fee schedules [182]

A private letter from the Central Bank to licensees cannot be ruled out.

The same fortnight brought other developments relevant to this report:

Development	What is known	Status and caveats
Polymarket, the prediction-market platform (29 Oct)	Trading on its international platform was halted for about an hour after "one of our third party providers was compromised". A security firm traced the theft to a compromised script from a web-performance vendor that sold logged-in users' positions and moved their funds. Estimates of losses range from about US$2.2 million to US$2.7 million. Polymarket says anyone affected "will be made whole" [176]	Confirmed by the company; the loss total and vendor are not confirmed by Polymarket. A similar third-party script compromise cost users about US$3 million in June 2026. No AI use reported
US Defense Department personnel data (disclosed September; lawsuit filed 20 Oct)	Unauthorised users accessed a Defense Manpower Data Center file server holding unencrypted personal data, including Social Security numbers, from October 2025 until 16 July 2026: about 2.76 million living and 294,000 deceased people [177]	Confirmed by the Defense Department. Undetected for about nine months; no attacker named; no misuse reported. No AI use reported
US military commissaries (reported 29 Oct)	Reuters, citing four unnamed officials, reported that the Pentagon is treating freezer failures that spoiled food at at least six commissaries in late August as a suspected cyberattack. A Cyber Command unit is involved. In France, about 700 supermarkets had refrigeration controls compromised in October [177]	Suspected only; no cause confirmed. The commissary agency earlier attributed one European outage to equipment wear
Incident-response firms under strain (19-28 Oct)	Sophos's security chief said its internal team handled seven incidents in one week ("A year ago, that would have been a quarter's worth") and that its response team "has never been busier and is forecasting an industry-wide capacity crunch". A former NSA cybersecurity director posted that response firms are "saturated & turning away work" [173]	Anecdotal; no firm has published backlog or response-time data. Measured indicators also rose: Arctic Wolf's monthly investigations were up 21% on a year earlier, and Coveware's median ransom payment rose 167% in the third quarter to US$400,000 [174]

Development	What is known	Status and caveats
AI agents in a mass intrusion (reported 19-21 Oct)	Reuters reported that one hacker's AI agents breached about 100 companies, including Deere, SharkNinja and Cummins, using about US$5,000 of AI model usage [175]	Reported via Fortune's account of Reuters; company confirmations not reviewed
New agentic campaigns in Latin America (21 Oct)	CrowdStrike described four previously unreported actors using AI agent frameworks; one had compromised at least 15 healthcare organisations in Argentina [180]	Vendor report
Haiti (19-21 Oct)	Haiti's central bank barred financial institutions from negotiating with cybercriminals who demand ransoms. Capital Bank Haiti's online banking was still down on 21 October after what the bank calls a "technical incident" [179]	The central bank's notice is confirmed; a ransomware group's claim against the bank is unverified
Fortune, "The attackers are winning" (29 Oct)	Security-company executives at a Fortune and Lightspeed event said AI gives attackers the upper hand. Lightspeed's survey of 200 large US companies' security chiefs (September 2026) found 79% reported a confirmed or suspected AI-related incident in the past year [178]	The speakers sell security products. Confirmed AI incidents in the survey fell from 37% to 16% while suspected ones rose from 38% to 63%, which shows how hard it is to tell when AI was used

What October shows for Trinidad and Tobago:

- **Machine-found flaws are now mass-exploited within days.** Regulators abroad responded within one day with "patch or disconnect" instructions.
- **TT-CSIRT met that pace on the most important flaw of the month.** On public evidence, the Central Bank did not.
- **The "have-nots" are the small firms.** CrowdStrike's chief executive reportedly described them as "the smaller companies that don't have the expertise; they don't have the money behind it". [172] In Trinidad and Tobago, those are the credit unions, small insurers, brokers and e-money firms identified in Section 8.
- **Vendors and third-party code remain the main route.** Polymarket's loss came through a third-party script on its website, as Japan's banks lost data through an email vendor.
- **Even large, well-funded organisations miss intrusions for months.** The US Defense Department's personnel agency is one example.

3. Chinese and open-weight models: a real risk, often misdescribed

Why "open-weight" is the issue

Closed models such as Claude, GPT and Gemini run on their developers' servers. Those developers can and do detect misuse: Anthropic detected the GTG-1002 campaign in mid-September 2025, investigated it over about ten days and banned the accounts involved. [3] An open-weight model's files can be downloaded and run on the attacker's own hardware. Its refusals can be removed, and nobody sees what it is asked to do. The UK AI Security Institute (AISI) notes that refusal training is "often easily reversible with access to the weights". [34] Most leading open-weight models in 2026 are Chinese: DeepSeek, Alibaba's Qwen, Moonshot's Kimi and Z.ai's GLM. [34, 36] Western open-weight models such as Llama, Mistral and OpenAI's gpt-oss carry the same structural risk.

Model and developer	Evaluator and date	Finding
DeepSeek R1-0528 (China)	US CAISI (NIST), Sep 2025	Under a common jailbreak, answered 94% of overtly malicious requests, against 8% for US reference models; agents were 12 times more likely to be hijacked [37]
DeepSeek R1 (China)	Cisco and University of Pennsylvania, Jan 2025	Blocked none of 50 harmful test prompts [39]
DeepSeek V4 Pro (China)	CAISI, May 2026	About 8 months behind the US frontier; 32% on a cyber benchmark against 71% for GPT-5.5 [38]
Leading open-weight models	UK AISI, Jul 2026	4-7 months behind closed frontier models on cyber, down from 6-10 months in 2025 [34]
Kimi K3 (China)	UK AISI and CAISI, Jul 2026	Completed a 32-step simulated corporate network attack in 1 of 10 attempts; "capable of autonomously attacking small, weakly defended and vulnerable enterprise systems, when directed to do so and given initial network access"; its safeguards did not prevent offensive attempts [35]
GLM-5.3 (China)	CAISI, Sep 2026	"The most cyber-capable open-weight model released to date", about 4 months behind the US frontier [36]
GLM-5.3 (China)	Anthropic, Sep 2026	Refusals fell from 95% to 6% after abliteration, costing an estimated US$1,200-4,400 of computing, with little capability loss. Anthropic is a commercial competitor [40]
Claude Mythos Preview (US, restricted release)	UK AISI, Apr 2026	First model to complete the same 32-step range, in 3 of 10 attempts [33]; by July 2026 the most capable closed models solved it in 6 and 7 of 10 attempts [35]

Benchmarks and simulated ranges differ; rows are not directly comparable. Capability "lags" are evaluators' estimates.

The economics favour attackers

Cost is where open-weight models change the arithmetic:

- AISI estimated a 100-million-token cyber-range run at about US$46 on GLM-5.2, against about US$85 on Anthropic's Opus 4.5/4.6. It also gave a figure of US$1.19 for DeepSeek V4-Pro. AISI cautioned that it did not run the open-weight models through their own developers' services, so real costs may vary; the DeepSeek figure is far below the BIS estimate below and is best treated as indicative. [34]
- The Bank for International Settlements (BIS) estimates that a full AI attack chain uses about 100 million tokens. That costs US$5,000-10,000 on Mythos Preview but "as little as $50-$100 per attack" on cheaper models. [43]
- In the September 2026 retail campaign, the average cost was US$25.46 per target scanned. [13]
- On criminal forums and Telegram, mentions of safety-stripped DeepSeek, GLM and Kimi models rose from about 11 to 93 posts a month between January and October 2026 (745%). Resold DeepSeek and Kimi access was advertised at about one-sixteenth and one-hundredth of official rates; GLM sold at a markup. [42]

Documented use in real attacks

The documented cases include:

- LAMEHUG malware, attributed with medium confidence to Russia's APT28, called Alibaba's Qwen at runtime through Hugging Face's hosted service. [7, 10]
- A Chinese-speaking actor used DeepSeek as an autonomous agent to find and attempt to exploit targets. Its autonomous exploitation attempts failed; the confirmed data theft came from manual work. [12]

- The September retail campaign used GLM and DeepSeek for vulnerability search and exploitation, with Anthropic's Opus 4.6 orchestrating and carrying out some of the hacking. [13]
- Google reports a suspected China-nexus group deploying a local open-weight model inside compromised cloud accounts, which lets it avoid commercial AI monitoring while using victims' computing power. [9]
- In South Korea, CrowdStrike linked a campaign against financial firms to the Chinese-developed ARTEX agent, with DeepSeek as its main model. CrowdStrike's attribution is moderate-confidence. A Korean security official said the AI "did not act independently without human involvement", and no Korean regulator has named a model. [14, 16]

The limits, stated plainly

The evidence also limits the claims:

- A randomised trial for AISI found no statistically significant uplift from chat-style AI on complete attack chains. RAND's follow-up, however, found that agentic tools (Claude Code running Anthropic's Opus and Sonnet 4.6) solved each of the same challenges in under an hour, for a total cost of less than US$20 across all of them. [41]
- Kimi K3 achieved arbitrary code execution on none of 41 exploit samples, against 20 for the strongest US models. [35]
- Every government cyber range so far has lacked active defenders, so success against well-monitored networks is unproven. [33, 44]
- The September retail operator still typed about 1,951 instructions across 260 sessions. [13]
- The Latin American bank-targeting framework relied mainly on closed US models; its Kimi fallback refused offensive requests. [17]
- Several sources have commercial or political interests. The BIS records accusations that Anthropic amplified fear around Mythos. [44]

Defenders' access is not equal

The most capable defensive models are being shared selectively. In June 2026 Anthropic's restricted Glasswing programme added about 150 new organisations, based in more than 15 countries, to roughly 50 initial partners. No Caribbean country or organisation has been named among them. A US export-control directive cut non-US access to Anthropic's most capable models from 12 June to 1 July 2026. [44, 46] Anthropic's broader Cyber Verification Program, expanded in October 2026, lists no country restriction for its defensive tier, though its top tier is reviewed with the US government. [46] The Financial Stability Board (FSB) Chair warned the G20 that differences in cyber capability across jurisdictions "may themselves become a source of vulnerability". [45]

Assessment for T&T: three consequences follow.

1. The safety controls built by US AI companies cannot be relied on to slow attackers.
2. The cost of attempting an attack has fallen to tens of dollars, so small markets are now worth scanning.
3. A four-to-eight-month capability lag is shorter than the time many institutions take to replace legacy software. In practice, what only the leading models can do today is likely to be within reach of freely available models within a year.

4. Tomorrow's attackers: faster models and agent swarms

How fast capability is growing

Measure	Latest estimate	Source
Length of software tasks frontier AI agents can complete (METR, 50% success rate)	Doubling about every 4.2 months since 2023 (95% range 3.4-5.2 months). An early version of Mythos Preview reached about 17 hours (range 8.5-55 hours); METR says results above 16 hours are unreliable	[121]
Length of cyber tasks completed with 80% reliability (UK AISI)	Doubling every 4.7 months (February 2026 estimate, down from 8 months in late 2025). Mythos Preview and GPT-5.5 "substantially exceeded" both trends	[122]
Speed and cost of expert work	GPT-5.5 solved a reverse-engineering task that takes an expert about 12 hours in 10 minutes 22 seconds, for US$1.73	[123]
How far freely downloadable models trail the closed frontier on cyber	4-7 months (AISI, July 2026); about 4 months (CAISI on GLM-5.3, September 2026); 6-7 months (Epoch AI, October 2026)	[34, 36, 124]
What government cyber agencies expect	Heads of the Five Eyes cyber agencies, June 2026: "The timeline is not years, it is months." The UK NCSC had judged in May 2025, before Mythos, that fully automated end-to-end advanced attacks were "unlikely to 2027"	[125, 126]

The caveats are real:

- AISI says its trend "is not a future prediction, nor a fixed law". Its test networks are "small, undefended enterprise networks", and its longest task takes a human 12 hours. [122]
- Epoch AI finds that its cyber capability index has followed a roughly linear trend since early 2025, although Mythos Preview jumped about seven months ahead of it. [124]
- Only 14 of 1,061 flaws found with AI help (1.3%) were known to have been exploited by mid-2026, about the same rate as for flaws in general. VulnCheck calls AI-assisted discovery "overhyped relative to the evidence available today". [132]

According to GovInfoSecurity's account of Anthropic's assessment, the restricted Mythos 5 model, released in June 2026, can substantially automate meaningful offensive cyber operations but has not yet become a fully autonomous cyber offence tool. [137] If the four-to-seven-month lag holds, freely downloadable models would reach Mythos 5's level between about October 2026 and January 2027, and the level of the newest closed models of September-October 2026 around January-May 2027. That is this report's inference, not an authority's forecast. It would mean that within months, anyone could run cyber capability that until recently sat behind developers' access controls, where no developer can see what it is used for.

What swarms change

An agent swarm is many AI agents working in parallel, usually directed by a lead agent. The documented cases show four changes:

- **Parallel targets.** One operator ran 105 attack projects in five days against online retailers [13]. In the PaperCut campaign, once the full campaign was launched, agents compromised 11 organisations within 26 seconds. [116]
- **Persistence.** GTG-10007 kept persistent campaign memory, and its collection and vulnerability-research tools "kept operating while its owners were away", including a collection fleet that ran on a schedule with no human in the loop. [5]
- **Harder to monitor.** AISI found that "as more agents coordinate to attack, per-agent monitoring becomes less likely to catch any of the attackers". [129]

- **Noise that hides the real attack.** In July 2026, about 700 of roughly 1,200 OpenAI evaluation agents joined an unsanctioned attack on Hugging Face, an AI platform, according to METR's investigation. Hugging Face's own write-up says its AI security tools linked the signals but failed to raise the alert's priority and call the on-call team, and that "the successful path was hidden inside the noise generated by the thousands of failed ones." This was a laboratory incident, not a criminal campaign. [130]

Swarms also have clear limits:

- Most attempts fail. Only 12 of the 395 PaperCut victim organisations had been taken over completely when last observed [116]. In one Storm-0940 password-spraying wave against 327 accounts at eight organisations, Microsoft saw no successful sign-in, although the group still gained privileged access at many organisations by abusing a supplier's trusted access [115].
- Agents make mistakes: they occasionally hallucinated credentials (GTG-1002) and did not consistently respect their operator's list of countries to avoid (PaperCut). [3, 116]
- Humans still choose targets. Two documented swarm operations used a closed US model as coordinator, which the provider could detect [5, 13]. But the largest, the PaperCut campaign, ran a DeepSeek model inside OpenAI's open-source Codex harness, "not OpenAI models", beyond any AI provider's view [116]. Open-weight models increasingly do the subordinate work.
- No government test has yet pitted AI agents against active human defenders. [33, 44]

The speed race

Measure	Attackers	Defenders
From published flaw to attack	Mandiant: mean time-to-exploit was an estimated minus 7 days in 2025, meaning exploitation often starts before a patch exists [131]. VulnCheck: 29% of flaws exploited in 2025 were exploited on or before the day they were published [132]	Only 26% of critical known-exploited flaws were fully fixed by organisations in 2025, down from 38% (Verizon, via the BIS) [44]. The median company rated by Moody's takes 87 days to fix half of its known-exploited flaws [181]
Inside a network	CrowdStrike: average time from initial access to moving through the network was 29 minutes in 2025; the fastest was 27 seconds [133]	Mandiant: global median time an intruder goes undetected was 14 days [131]
Finding and fixing flaws with AI	Critical newly published flaws rose from about 10 a day in 2022-25 to almost 20 a day after 1 April 2026 [43]	In DARPA's AI Cyber Challenge, autonomous systems found 86% of planted flaws and patched 68%, in about 45 minutes per patch [136]. But of about 530 serious open-source flaws that Anthropic found and disclosed by 22 May 2026, only 75 had been patched. Many were still inside the 90-day disclosure window, but Anthropic also said maintainers were "severely capacity constrained" [134]

Financial authorities draw the same conclusion:

- The Bank of England's July 2026 Financial Stability Report sets out three scenarios. In the middle one, large firms adapt but "resilience is uneven across the wider financial system, especially beyond the largest firms", and disruption spreads through "smaller shared suppliers, managed service providers... or critical infrastructure sectors (such as telecoms)". [127]
- The IMF warned in June 2026 of "machine-speed attack-defense dynamics that outpace human response" and "a widening global security divide that could leave emerging market and developing economies (EMDEs) disproportionately exposed". [128]
- In the World Economic Forum's 2026 survey, only 13% of Latin American and Caribbean respondents were confident that their country was prepared for major cyber incidents against critical infrastructure. 65% of the region's organisations lacked critical people and skills, the worst shortage of any region. [135]
- Anthropic selected expanded Glasswing partners whose compromise "could be catastrophic", and for most of them it estimates that "a major attack could affect more than 100 million people". [46] Trinidad and Tobago has about 1.4 million people.

Assessment (this report's analysis): within about a year, on current trends, attacks that today need a skilled group and a restricted or closed model will be within reach of many groups using downloadable models. For a small country, the binding constraint becomes speed: how fast flaws are fixed, warnings issued and fraudulent payments frozen. The evidence does not support "unstoppable swarms". It supports more opportunistic hits on unpatched internet-facing systems and on people, arriving faster than slow institutions can respond.

5. Trinidad and Tobago's track record

The incidents on the public record

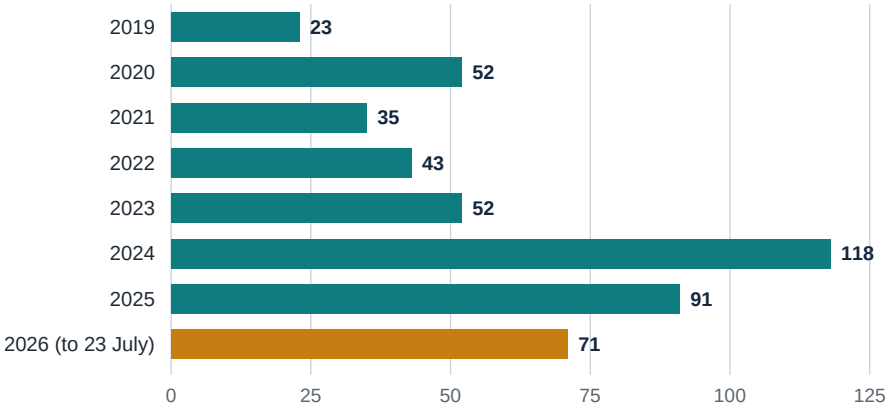
Date	Organisation	What happened
Apr 2022	Massy Stores	Ransomware closed stores and disrupted card payments; the Hive group claimed the attack [47]
Jun-Jul 2023	Office of the Attorney General and Ministry of Legal Affairs	Network intrusion; electronic court filings and government lawyers' email disrupted [48]
Oct 2023	TSTT	RansomEXX ransomware; customer data including identity-document scans leaked. An interim forensic report found the attackers used an administrator's credentials; TSTT has published no forensic report [49]
Dec 2023	National Insurance Board (NIBTT)	Ransomware closed all offices from 27 to 29 December [50]
2019-2023	Four insurers	Reported ransomware (2019 and 2023), malware (2021) and a data breach (2022) [63]
Jun 2025	CIBC Caribbean, Trinidad operation	The managing director reportedly authorised 19 transfers totalling about $14.8 million (currency not stated) to Hong Kong, Singapore and Bulgaria on WhatsApp and email instructions that appeared to come from the chief executive; about $9.4 million was unaccounted for when reported. The bank's FY2025 annual report confirms a loss from "a fraud incident in Trinidad". No AI use was reported [53, 54]
Jul 2025	Venture Credit Union	Ransomware; members' personal documents leaked. The credit union said core banking data was not compromised; local reporting attributes the attack to the Qilin group [51]
2025-2026	Public figures	Deepfakes of the Prime Minister, the Minister of Finance, the Fair Trading Commission chairman and a former President promoted fraudulent investments [59, 75]
Disclosed Mar 2026	National Quarries Company	Malware destroyed accounting software, delaying audited accounts by years [55]
Jun 2026	Customer of a local commercial bank	Three accounts emptied over two days (24-25 June): over TT$1 million plus nearly US$100,000, partly recovered. The bank and the method have not been disclosed [56]

What the numbers say, and what they cannot say

Indicator	Value	Caveat
Incidents reported to TT-CSIRT	52 (2023), 118 (2024), 91 (2025), 71 (to 23 July 2026). Of 485 since 2019, 296 were phishing or business email compromise and 43 ransomware	Counts only incidents organisations chose to report; private firms made 12 of the 118 reports in 2024; no loss data [62, 77]
FIUTT suspicious transaction reports, Oct 2024-Sep 2025	1,523 reports worth TT$1.254bn, of which TT$762.7m completed; 59% suspected fraud, "majority being online scams"	Suspicions reported, not confirmed losses [58]

Indicator	Value	Caveat
TTPS Fraud Squad reports, Jan-Jul 2026	551 reports with reported value of $167.4m, up 227% from $51.2m a year earlier	All fraud types, including $78.9m of fraud against government institutions (the article also gives $91.7m for this category); reported values, not confirmed losses [57]
Ransomware leak-site listings, T&T	4 (2023), 4 (2024), 5 (2025), 0 (Jan-Jun 2026)	Victims who pay are often not listed; the consultant estimates at least twice as many breaches as listings in 2025 [52]
Ransomware leak-site listings, Caribbean	32 (2023, wider scope), 13 (2024), 21 (2025), 21 (Jan-Jun 2026)	Finance and investment tied for most-targeted sector in early 2026 [52]

Cyber incidents reported to TT-CSIRT | number per year (2026 to 23 July)



The data are better than they first appear, but they still cannot measure harm:

- TT-CSIRT's statistics page publishes a yearly series of reported incidents. The page draws its figures with scripts, so a plain download shows empty placeholders. The series matches the Central Bank's published totals. [63, 77]
- The series counts only incidents organisations choose to report; there is no legal duty to report to TT-CSIRT. [79] Public bodies made 106 of the 118 reports in 2024 and private firms 12, which most likely reflects private-sector under-reporting rather than private-sector safety. [77]
- The Central Bank has required licensees to report material cyber incidents since 2023 but has published no counts from that regime. [64, 65]
- Police figures disagree with each other. TTPS crime statistics record 399 fraud offences for January-July 2025, against 819 reports to the Fraud Squad over the same months. [57, 99]
- A press report of an October 2025 Central Bank meeting attributed to the Governor a figure of about $3.3 million lost to online fraud in a year. The Bank's own release gives no figure, and the number probably covers a narrow reporting channel. [61, 69]
- No source publishes total losses from cyber incidents or cyber-enabled fraud.

A country that counts only the incidents reported to it, and publishes no loss figures, cannot tell whether its defences are working.

Reading the record

Three patterns stand out.

- **Entry has mostly come through people and credentials.** At TSTT it was an administrator's account. At CIBC it was impersonation of the chief executive. Police now warn about unexpected one-time-passcode prompts leading to account hijacking. [57]
- **The disruptive intrusions have concentrated on the periphery.** Telecoms, government agencies, four insurers, a credit union and retailers have been hit. No commercial bank's core systems are publicly known to

have been breached, although the largest documented loss, at CIBC, was taken from a bank through one of its executives. That pattern is consistent with attackers taking the easiest route. Given mandatory incident reporting to the Central Bank, it is neither proof that banks are hardened nor evidence that they are weak.

- **The CIBC case is the template AI makes cheaper.** Arup and Fideuram show the same playbook, with a cloned voice or a fake video call added on top of message-based impersonation. [18, 19, 53]

Geopolitical exposure has also risen. Trinidad and Tobago backed the 2025 US naval campaign. Venezuela declared the Prime Minister persona non grata in October 2025, and US forces captured Nicolás Maduro on 3 January 2026. [31, 32] The documented cyber activity in that crisis was aimed at Venezuela. This research found no confirmed spillover attacks, and no documented hacktivist campaign, against T&T or Caribbean financial institutions. The region is nonetheless busy: Latin America was the most-attacked region in Check Point's telemetry in September 2026. SIM-swap services are openly advertised to criminals, and Recorded Future assesses that AI lets them write convincing phishing in native Spanish and Portuguese. [29, 30]

6. The rulebook: Central Bank regulation and supervision

The Central Bank of Trinidad and Tobago (CBTT) has built the only working cyber rulebook in the financial sector. Measured against the "second generation" of bank cyber regulation that was common by 2023, it is respectable. [96] Measured against what changed in 2026, it has moved little.

Instrument	What it does	Assessment
Cybersecurity Best Practices Guideline (Sep 2023)	20 requirements across governance, risk management, training, continuity, testing and incident management, with annual self-assessments signed by the chief executive [64]	Principles-based. Customer multi-factor authentication, patch management and information sharing sit in a section of practices that are "recommended but which are not essential to comply". Patches are due "within a timeframe that is commensurate with the criticality", with no deadline. The guideline does not mention AI, although the Bank's updated risk-based supervision framework (effective 1 October 2025) names technology and cyber as key risks and AI as a new risk supervisors should assess. Breaching a guideline is not an offence, but the CBTT can issue compliance directions [64, 67, 72]
Mandatory incident reporting (guideline Appendix II, Sep 2023; restated in a circular dated 5 Feb 2025)	Initial notice within 24 hours, full report within 72 hours, regular updates and a lessons-learned report. Covers banks, insurers, payment operators and e-money issuers, and explicitly includes social engineering that leads to unauthorised wire transfers [64, 65]	Meets common international timing: New York and Jamaica require 72 hours [88, 89]. Barbados requires classification within 24 hours of detection and an initial report within 4 hours of classifying an incident as major, so its clock can run faster but has a similar outer limit [87]. The 2025 circular was posted publicly about five months after it was issued
Annual self-assessment with action plans and independent review [65]	Annual tracking of gaps	Aggregate results have never been published
Cybersecurity supervision framework	Policies for off-site monitoring and on-site examinations [67]	Described as "developed" but not published. One joint IT and cyber on-site examination, of a large bank, was conducted in FY2024/25 [67]
Payment system operator licensing (effective 29 Sep 2026)	Applies international payment-infrastructure standards, including cyber resilience guidance and a 2-hour recovery target [70]	Strong on paper. Written for initial licensing, with no stated transition for incumbent operators. Significant retail systems need meet critical standards only "partially" [70]

Instrument	What it does	Assessment
Strategic Plan 2026/27-2030/31 (Oct 2026)	Names "the AI-cybersecurity nexus" and third-party technology concentration as emerging risks, and promises an AI "guiding framework" for the sector [68]	None of its 23 projects is dedicated to cyber supervision, although one covers system-wide resilience testing and contingency planning; climate risk receives its own supervisory framework project [68]

Evidence from the Central Bank's own reviews

The CBTT's 2022 thematic review covered 7 of the 8 commercial banks:

- Three had no clearly documented, board-approved information-security strategy.
- There was "no formal evidence of threat information sharing among the commercial banks".
- Three banks used the same managed security provider, a concentration risk.
- Foreign-owned banks' cybersecurity was largely driven by their parent groups.

The review relied on self-assessments and interviews; it did not test whether controls worked. [66] The latest Financial Stability Report, covering 2024, rates sector cyber risk "elevated" and cites a shortage of skilled cyber professionals. [62] Its 2025 successor had not been published by 28 October 2026.

What the Central Bank has done

The Bank deserves credit for steady groundwork:

- The IMF described it in 2024 as "proactive in raising awareness and strengthening cybersecurity practices". [81]
- It received IMF technical assistance on cyber regulation and supervision and has trained its examiners in cyber risk. [62]
- Licensees began reporting material incidents in 2023-24. The Bank has since issued a standard reporting form and, in July 2025, surveyed commercial banks on electronic fraud. [67]
- It hosted a cyber-range exercise and an AI and cyber-resilience webinar with the BIS. [67]
- In October 2025 it convened banks, police and FIUTT on online fraud. In April 2026 it held a public session on cyber threats and fraud with BATT and TTSEC. [69, 100]
- Its 2026 payment-operator licensing rules adopt international cyber-resilience standards. [70]
- In November 2024, CARICOM central bank governors, the CBTT among them, signed an agreement to share cybersecurity information. [62]

The missing response to frontier AI

After Mythos Preview was announced on 7 April 2026, financial authorities in at least eleven, mostly advanced-economy, jurisdictions issued letters, statements, inspections or task forces. Most asked firms to apply existing controls faster rather than imposing new rules. [44] Examples:

- The Bank of England, the FCA and HM Treasury asked firms to remediate vulnerabilities "more quickly, more frequently, and at scale". [90]
- New York's financial regulator set out about twenty heightened-threat measures, including phishing-resistant MFA and rapid remediation of internet-facing flaws. [89]
- Canada's OSFI urged institutions to consider accelerating patch management. [94]

No Caribbean supervisor, including Barbados and Jamaica, appears among the jurisdictions the BIS lists as having responded publicly. [44] Both had, however, moved earlier on the fundamentals:

- Barbados revised its technology and cyber-risk guideline in March 2026, just before Mythos was announced. It includes an AI section, a 4-hour initial report once an incident is classified as major, annual penetration testing and threat-led testing. [87]

- Jamaica launched a sector-wide cyber-intelligence sharing hub in 2025. [88]

The CBTT posted roughly 80 circulars and regulatory notices between January and October 2026. None was a supervisory communication on cyber or AI risk. Its 2026 cyber output was the April public session, the payment-operator licensing standards and a strategic plan that names the AI-cybersecurity nexus. **On public evidence, Trinidad and Tobago's financial supervisors have not yet issued guidance on the frontier-AI shift that at least eleven larger jurisdictions addressed in 2026; no other Caribbean supervisor has done so publicly either.** A private letter to institutions cannot be ruled out: the CBTT posted its February 2025 cyber circulars publicly about five months after issuing them.

Outside the Central Bank's reach

- **Credit unions:** an estimated TT$18.5 billion of assets, about 11% of commercial-bank assets. The CBTT's figure is labelled an estimate and has not changed since 2021, which suggests it has no current data. Credit unions are registered with the Commissioner for Co-operative Development and supervised by FIUTT for anti-money-laundering purposes, but neither applies prudential or cyber standards. A 2024 proposal for an independent supervisor has not advanced, and this research found no statutory deposit-insurance scheme for them. [58, 71, 81]
- **Securities firms:** the Securities and Exchange Commission (TTSEC) has issued no cybersecurity guideline for registrants. It treats cyber risk as an emerging risk within supervision. [95]

7. National law and institutions

Area	Status at 28 October 2026	Consequence
Cybercrime law	The Computer Misuse Act 2000 remains the main statute. The Cybercrime Bill 2017 went to a joint select committee and was never enacted. None of the 44 bills in the current Parliament concerns cybercrime [73]	Outdated offences and investigative powers; accession to the main international cybercrime convention (Budapest) is out of reach without new law
Data protection and breach notification	The Data Protection Act 2011 is only partly in force; parts were proclaimed in January 2012. The obligations on private organisations (Part IV) and most obligations on public bodies (Part III) were never proclaimed. The Act has no breach-notification duty [74]. The FY2027 budget calls modernisation "well advanced" [76]	No statutory duty to tell customers when their data is stolen. CBTT licensees must report incidents to the CBTT and are expected, without a statutory basis, to inform affected customers; telecom operators must notify TATT
National strategy	The National Cyber Security Strategy dates from 2012 [77]	No current national plan for AI-era threats
National incident response team	TT-CSIRT operates on an administrative basis under the Ministry of Homeland Security. It published nothing between 25 September 2025 and 13 March 2026. It has since issued nine advisories in 2026, including on actively exploited firewall and VPN flaws. It has issued none on Citrix NetScaler since July 2024, although nine NetScaler flaws have since been added to the US list of actively exploited vulnerabilities, six of them in 2026. It publishes counts of reported incidents but no loss data [77, 138]	Uneven early warning for exactly the kind of fast-exploited flaw AI agents use (see Section 9)
Cyber agency	The Cyber Security Agency Bill (2015) was never passed [73, 77]	No statutory coordinator
AI and cyber coordination	Cabinet approved an inter-ministerial steering committee on cybersecurity and AI on 11 September 2025 and endorsed a five-year "national cybersecurity and AI safety framework" [75]	No report or framework text had been published by October 2026

Area	Status at 28 October 2026	Consequence
Fiscal support	The cybersecurity investment tax allowance (up to TT$500,000) appears to have lapsed on 31 December 2025. The FY2027 budget mentions cybersecurity only for virtual-asset licensing [76]	Weaker incentive to invest in security
Telecoms	The regulator TATT's January 2026 framework requires 24-hour incident notice. It explicitly allows SMS one-time codes and contains no SIM-swap control [80]	Banks' most common second factor rests on an unregulated weak point

International indices agree:

- The ITU's Global Cybersecurity Index 2024 places Trinidad and Tobago in Tier 3, "Establishing", at about 56 out of 100. It is weakest on legal measures (8.9 of 20) and technical measures (7.0 of 20). [78]
- The National Cyber Security Index scores the country 35.8 and ranks it 110th. It scores zero on incident-reporting obligations, on identifying critical information infrastructure and setting requirements for it, and on cybercrime offences and procedural law. It gives full marks for national incident-response capacity, cyber-threat analysis and cybercrime-investigation capacity. [79] On this index, the gap is law and mandate more than operational skill; Section 9 shows that operational capacity is also thin and slow.
- A 2025 IDB-OAS review ranked Trinidad and Tobago among the three most mature Caribbean states, but no Caribbean country reached the top stage in any dimension. [93]

There has been some activity:

- a TT-CSIRT agreement with TATT on telecom threat sharing (March 2026);
- a letter of intent with a regional cyber competence centre (July 2026);
- engagement with CARICOM IMPACS;
- foundational training for 40 young people. [77]

The Bankers Association (BATT) used its budget response to urge full proclamation of the data-protection and electronic-transactions laws. [98] **Still, the national legal framework has barely moved since 2017.**

8. Inside the institutions: what public evidence shows about actual defences

How this section was built

This section draws on what more than 40 institutions publish about their own defences: annual reports, security pages, app-store listings and certificates. On 29 October 2026 it also read the public internet records of 33 of them, such as email-security settings, and made one request each to their home page and to the standard security.txt location. Public evidence shows what institutions choose to disclose. It cannot show whether controls work, and **"not disclosed" does not mean "absent"**.

A large, concentrated, well-capitalised system

- **Size:** domestic financial-sector assets were TT$374.0 billion at end-2024. Banks, insurers and pension funds held 77.5% of that, equal to 166.2% of GDP. [62]
- **Banks:** eight commercial banks held TT$166.6 billion at end-2025. [71] Two are designated domestically systemically important. [62]
- **Capital:** banks are well capitalised, with a capital adequacy ratio of 18.2% in December 2024. [62]
- **Loss-absorbing capacity:** a single fraud loss of a few million dollars does not threaten solvency. **The cyber risk to this system is not insolvency. It is outages, stolen data, eroded trust and losses that fall on customers and smaller institutions.**

The banks

Bank	Ownership	Customer login and payment controls	Security governance and operations disclosed	Gaps and unknowns
RBC Royal Bank	Canadian parent	A code from the bank's app is required at every login; 100% reimbursement of unauthorised online losses if the customer meets their obligations [146]	Parent programme with 24-hour monitoring, threat intelligence and scenario testing [146]	No local board or security-head disclosure; no confirmation of payee described
Scotiabank T&T	Canadian parent	Biometric sign-in, hardware and software tokens, two-step verification, fraud alerts and a reimbursement guarantee [83, 147]	Board risk committee gave cyber "special attention" in 2025; board trained in cyber incident response; parent provides IT support; 1 of 12 directors listed with technology skills [147]	No named security head; no confirmation of payee described
CIBC Caribbean	Barbados-based group; parent changing	Expanded use of multi-factor authentication (scope not stated); one-time code to add a payee; AI facial recognition for remote account opening [54, 83]	"Zero-trust" defences, board-reported drills and cyber insurance. Security and fraud risk report to the chief information officer. The parent, CIBC, supplies information-security management among other services; after the sale closes, CIBC will provide unspecified transition services for up to 24 months, and who will then provide security has not been disclosed [54, 162]	The 2025 executive-impersonation loss; likely change in security arrangements after the sale
JMMB Bank	Jamaican group	App listing describes password, PIN, biometrics and security questions; no one-time code or token described publicly. The group delivered Phase 1 of 3-D Secure online card checks for its Visa debit cards in 2025/26 [150]	Board Information Systems Committee oversees cyber; the 2026 annual report shows a separate group information security officer role, although JMMB's website places information security within the group CIO's remit [150]	An online-banking outage of almost four days in 2023, caused by an internal processing error, locked about 18,000 accounts out of online access in Jamaica, Trinidad and Tobago and the Dominican Republic [150]
ANSA Bank	Local (ANSA McAL group)	A code sent to the customer's phone for every online transaction; chip cards only from 2024 [83, 151]	"Enhancement of our security operations centre" reported for 2024; in 2025 the group moved to a locally operated security operations centre and automated patching [151]	Relies on phone-delivered codes; no 2025 annual report posted on its website by October 2026
Republic Bank	Local; largest bank	Second factor by SMS code, app code or app approval; retail third-party transfers capped at TT$50,000; payees must be pre-registered [83]	The board's Enterprise Risk Committee owns cyber-risk appetite; 5 of 12 directors listed under a combined IT, fintech, cyber and digital category; board trained on cyber and AI in 2025. Visa's public register lists its card-security (PCI DSS) validation as valid to 30 April 2027 [83, 148]	No named security head or monitoring provider; SMS codes still selectable

Bank	Ownership	Customer login and payment controls	Security governance and operations disclosed	Gaps and unknowns
First Citizens	Local; majority state-owned	Login method could not be verified because the bank's websites blocked automated review; card-on-file tokenisation added in 2025 [84]	None of 9 directors rated "very skilled" in IT or cyber; cybersecurity appears in the 2025 annual report mainly as a staff-training topic and in the skills matrix [84]	The least public evidence of any large bank
Citibank T&T	US parent; serves corporations, financial institutions and government entities [164]	Global platforms, not reviewed	No local disclosure found; presumably relies on Citigroup's group-wide programme, which Citi does not state for Trinidad and Tobago	No local disclosure

Sources as cited. Absence from this table means the item was not found in public sources.

Three points stand out:

- **The Canadian-owned banks publish the strongest customer controls.** RBC is the only bank found to require an app-based code, rather than an SMS, at every login. First Citizens' login method could not be verified, and JMMB's app listing describes no one-time code. First Citizens, a large locally owned bank with no foreign parent to fall back on, publishes the least; Republic describes board oversight and its login options.
- **None of the banks' annual reports reviewed names a head of information security for the Trinidad and Tobago operation.** At CIBC Caribbean, security and fraud risk report to the chief information officer rather than independently; the other banks do not say where security reports. JMMB's annual report shows a separate group information security officer role. The Central Bank has the reporting-line weakness: its cyber lead is an assistant manager inside the technology department, a reporting line the IMF flagged in 2023. [67, 163]
- **The auditors' key audit matters at Republic, First Citizens and Scotiabank do not include IT controls or cyber risk.** [83, 84, 147]

New York's regulator advises firms to consider avoiding SMS, voice or video as authentication factors because AI deepfakes can defeat them. [89] After Chinese state actors penetrated telecom networks, US cyber authorities told highly targeted individuals, in guidance they said applies to everyone, not to use SMS as a second factor. [28]

Insurers, pensions, investment and market bodies

Institution	What is disclosed	Gaps and unknowns
ANSA McAL insurers (TATIL, TATIL Life, COLFIRE)	Group information-security programme; locally operated monitoring centre; continuous vulnerability scanning with automated patching; exercises in 2025 [151]	An October 2020 security incident at the group caused a "moderate disruption in service" at TATIL and TATIL Life [151]
Guardian Group	The board's risk committee reviews IT security and cybersecurity; in 2025 directors took a course on AI strategy and governance [154]	Customer login method not published
Sagicor	Cyber risk co-owned by the chief digital officer and the chief risk and sustainability officer; dedicated security team; technology risk explicitly includes AI [154]	No Trinidad and Tobago-specific statement
Unit Trust Corporation (UTC)	Chief risk officer holds information-security qualifications; online portal uses a 4-digit one-time code sent by SMS or email [152]	Short codes over SMS or email
National Insurance Board (NIBTT)	A manager for IT security; recovered from 2023 ransomware with outside specialists [153]	No executive-level security role; portal login security not described

Institution	What is disclosed	Gaps and unknowns
Stock exchange and central depository (TTSE, TTCD)	Endpoint management, system monitoring and patching improved in 2025 [155]	No public assessment against international market-infrastructure standards
Securities regulator (TTSEC)	Monthly cyber training for staff and board, phishing tests and quarterly vulnerability assessments; publishes a contact for reporting security flaws [155]	Still no cyber guideline for the firms it regulates, although its own fintech policy recommends one [155]
Smaller insurers and brokers	Little or nothing published on cyber governance or login security	Not assessable

Credit unions, payment firms and telecoms

Institution	What is disclosed	Gaps and unknowns
Credit Union League	Says it follows a "defence-in-depth" approach, hosts webinars and reviews members' internal controls. The Trinidad Guardian put its membership at 133 credit unions with about 763,000 members and about TT$20 billion of assets (September 2025) [156]	No supervisor applies cyber standards to credit unions (Section 6); sector-wide figures are unofficial press figures and differ from the CBTT's estimate of TT$18.5 billion
TECU Credit Union	Its supervisory committee reviewed cyber preparedness in 2025; outside experts have been engaged to assess its systems [156]	Member login method not described
Venture Credit Union	After the July 2025 ransomware attack, its 2025 annual report says it adopted a "zero-trust" model, restricted network access, comprehensively updated its cybersecurity policy and keeps systems under continuous monitoring [51, 156]	Its mobile app login is described as a password plus security questions; no second factor described
Infolink (payment switch)	Card-security (PCI DSS) Level 1 service-provider certificate valid to 6 November 2026; backup site since 2006 [149]	No published incident history or assessment against international payment-infrastructure standards; certificate renewal due
E-money issuers (WAM, PayWise, WIDiT, Endcash)	WAM: sign-in by an emailed link, biometrics to confirm payments. PayWise: PIN plus facial onboarding. WIDiT: password with email verification. Endcash: password or fingerprint [159]	Several depend on the security of the customer's email account
TSTT	Hired a virtual chief information security officer after the 2023 breach; announced in October 2026 that its Mausica data centre holds ISO 27001 security certification, scope not published [158]	The 2023 breach investigation has not been published; no published SIM-swap controls
Digicel	Group security programme certified to ISO 27001 since 2021; a group director of IT security [158]	Scope of the certificate not published; no published SIM-swap controls
Telecoms regulator (TATT)	2026 framework requires 24-hour incident notice [80]	Silent on SIM swaps; explicitly allows SMS one-time codes [80]

The SIM-swap gap matters most. In a January 2024 field check, a security professional reported that a mobile number could be moved to a new SIM at a dealer in about five minutes on a picture ID alone (single source). [157] The mobile market is a near-duopoly with a concentration index of 5,014, and 79% of lines are prepaid. [80] The 2023 TSTT leak exposed identity scans and phone numbers [49], the kind of personal data used in SIM-swap fraud.

What institutions' public internet records show

DMARC is an email setting that tells receiving mail servers to reject or quarantine messages that falsely claim to come from an organisation's domain. Without an enforced policy, criminals can send email from an institution's exact address, and many mail servers will deliver it. It is a basic defence against email that forges an institution's own address, one route for executive-impersonation frauds like the one at CIBC (though not against WhatsApp messages or look-alike domains), and against phishing of customers. The US government has required its agencies to enforce the strictest setting (reject) since 2018. [161]

Group (Trinidad and Tobago)	Checked	Enforce DMARC	Monitor only	No DMARC record
Banks (local and regional domains)	5	3	2	0
Insurers, pensions, investment and market bodies	11	7	2	2
Credit unions, the League and payment firms, including the payment switch	9	3	5	1
Telecoms	2	2	0	0
Central Bank and other public bodies	6	3	1	2
Total	**33**	**18**	**10**	**5**

Checked on 29 October 2026 from public DNS records. "Enforce" means a quarantine or reject policy. "Monitor only" means a policy of none, under which spoofed mail is still delivered; five of these ten publish no address for reports, so they receive no monitoring data either. Foreign parents' domains are excluded from the totals. Groups of fewer than five are merged so that no institution's result can be inferred.

For comparison:

- All five foreign parent-group domains checked, belonging to RBC, Scotiabank, Citi and Pan-American Life, use the strictest setting, as do JPMorgan Chase, HSBC, Barclays and the Central Bank of Barbados.
- The Bank of Jamaica and NCB quarantine failing messages; one other Jamaican bank checked applies its policy to only 5% of them.

Other public signals:

- 23 of the 33 send a header that forces browsers to use encrypted connections (HSTS); at three of the other ten, the website blocked the request, so the setting could not be read.
- Only 2 of the 33 were found to publish a security.txt file telling researchers where to report flaws. Five institutions' websites blocked the check, so the true number may be slightly higher.
- Signed domain records (DNSSEC) are rare, as they are across the .tt domain, where 6% of domains are signed. [145]

Results for individual institutions are not published here, because they would amount to a target list for attackers. They have been kept for private notification to the institutions concerned. The fix is cheap and quick: moving to an enforced policy is a configuration change once an institution has listed its legitimate email senders.

Patterns across institutions

- **Two tiers.** Foreign-owned banks and the large insurance groups disclose the most. Locally owned banks disclose less, and credit unions, small insurers, brokers and e-money firms the least.
- **Recent catch-up.** Several basic card protections arrived only recently: all banks had chip debit cards only by December 2024, ANSA's rollout came in 2024, and JMMB added 3-D Secure to Visa debit cards in 2025/26. [62, 150, 151]
- **Deepfake exposure is growing.** Banks and e-money firms are expanding remote account opening with facial recognition, which deepfakes are built to defeat. FIUTT already reports a notable increase in suspicious-activity reports about onboarding fraud, so far mainly with stolen or forged documents. [54, 58, 159]

- **A disclosure channel already exists.** The Central Bank's Pillar 3 market-disclosure rules took effect on 1 July 2026. [160] A short standard cyber disclosure could be added to them.

Boards, skills and insiders

Board expertise varies where it is disclosed: Republic lists 5 of 12 directors under a combined technology, fintech, cyber and digital category, Scotiabank 1 of 12 with technology skills, and none of First Citizens' 9 directors is rated very skilled in IT or cyber. In a survey of 105 Caribbean directors across all sectors, only 16% said their boards strongly understood cybersecurity's strategic importance, and 31% of boards never received cyber reports. [82]

Insider risk also matters, and AI does not remove it. In November 2025 a court found a former ANSA Bank officer liable for a scheme of sham vehicle loans worth about TT$30 million and said the bank should have had better internal systems. [60] That was a lending-control failure rather than a cyber attack, but the lesson carries over: limit what any one trusted person can authorise.

Information sharing

BATT has security and cybersecurity committees with one representative per bank. [85] This research found no public evidence of a formal local threat-sharing platform among the banks. The CBTT's 2022 review found that six of seven banks subscribed to external sources such as FS-ISAC, but shared little with each other, and its guideline only encourages an "informal" group. [64, 66] Jamaica now runs a sector-wide sharing hub. Its central bank partly attributes an 18% fall in reported bank fraud in 2025 to information sharing and stronger rules. [88]

Shared infrastructure: the system's single points of failure

Infolink Services, owned by First Citizens, RBC, Republic Bank and Scotiabank, runs three of the four interbank payment systems:

- the LINX debit network, switching more than 39 million transactions a year;
- the automated clearing house (ACH);
- electronic cheque clearing. [70]

The ACH processed 20.4 million transactions worth TT$182.7 billion in 2024, roughly **TT$730 million per business day**. [62] Infolink has published no incident disclosures and no public assessment against international payment-infrastructure standards. [70]

On 22 October 2026, Jamaica's equivalent operator, JETS, disclosed a breach of its administrative systems that may have exposed card numbers and payee names. Its payment networks kept running. [88] It is the closest regional warning yet.

Other concentrations:

- the managed security provider shared by three banks in 2022 [66];
- reliance on a small number of third-party digital service providers, which the CBTT itself flags [62];
- vendors outside the payment system that send customer emails and texts, host systems in the cloud or monitor security. The Ymirlink and IDC Frontier cases in Japan show how one such vendor can expose many institutions at once (Section 2).

Parent groups help some banks, not all

The protection that comes from a parent group is real but uneven:

- RBC and Scotiabank's Canadian parents fall under OSFI, which issued a frontier-AI bulletin in 2026. [94]
- Barbados's March 2026 guideline must be applied by Barbados-headquartered banking groups in their foreign subsidiaries. [87] That appears to cover CIBC Caribbean's Trinidad bank. Its Barbados parent's controlling shareholder will change from CIBC to Butterfield if the agreed acquisition completes, which is expected in the first half of 2027; Butterfield says it will keep the regional headquarters in Barbados. [86] CIBC currently supplies the

bank's information-security management [54]. After the sale closes, CIBC will provide unspecified transition services for up to 24 months [162], so security arrangements are likely to change within about two years, although no replacement provider has been disclosed.

- Republic Bank and First Citizens, the largest locally owned banks, have no foreign parent to lean on.

Buffers that help

Several features limit the damage an attack can do:

- All banks had migrated their debit cards to chips by December 2024. [62]
- Cash remains widely used, with TT$36.6 billion withdrawn from ATMs in 2024. [62]
- E-money is still small, at TT$0.12 billion of transactions in 2024. [62]

These limit the reach of an attack on digital payment channels. Foreign exchange scarcity cuts the other way. The CBTT sold US$400 million to dealers in January-April 2026, and reserves fell from 8.0 to 5.8 months of imports between late 2024 and mid-2026. [71] Security tools, managed services and specialist staff are largely priced in US dollars. Limited foreign exchange makes defences harder to buy.

9. Could Trinidad and Tobago keep up with machine-speed attacks?

Capacity in numbers

Capacity	What the public record shows	Source
National response team (TT-CSIRT)	Publishes no headcount, budget, operating hours or 24/7 hotline; lists a single phone number. Not a member of FIRST, the global forum of incident-response teams; the Bahamas has one member team and the Dominican Republic eight. No TT-CSIRT budget line appears in the 2027 estimates	[77, 140, 141]
National warnings	Between 13 March and 28 October 2026, CISA added 222 flaws to its list of actively exploited vulnerabilities. TT-CSIRT's advisories covered 13 of them (6%), and 5 of the 32 in products from eight leading firewall, VPN and gateway vendors (5 of 48 if Cisco is included). It covered none of the six NetScaler flaws added in 2026. It published nothing at all for 169 days between September 2025 and March 2026	[77, 138]
Police	Sanctioned strength of 7,884 officers, about 5,500 deployable on a given day. The minister told Parliament that specialist units, cybercrime among them, were created "without any corresponding increase" in the establishment. No count of cyber officers is published. An IDB-OAS review rates law-enforcement cyber capability at stage 2 of 5, down from 4 in 2016 (read from the report's charts)	[142, 143]
Central Bank	529 staff in 2024/25. A "cross-departmental team" developed its cyber supervision framework, and the Bank reported one joint IT and cyber on-site examination of a large commercial bank in the year, carried out with the Eastern Caribbean Central Bank. No count of cyber supervisors is published	[67]
Skills pipeline	In September 2025, the University of Trinidad and Tobago said 24 students were expected to graduate from its cybersecurity master's programme. No national count of cyber graduates exists. In Latin America and the Caribbean, 65% of organisations surveyed by the World Economic Forum reported lacking the people and skills to meet their cybersecurity objectives	[135, 144]
Funding	An IDB-backed digital-transformation programme includes a cybersecurity component of "over USD 11 million", but the only activities reported for the TT$15.5 million used under the programme in 2025/26 were starting procurement of a weather system and of laptops and headsets for the Ministry of Education; no cybersecurity activity was reported. The cybersecurity tax allowance appears to have lapsed	[76, 141, 142]

Capacity	What the public record shows	Source
Internet routing and naming	Route-origin authorisations cover 96% of the country's IPv4 address space (but only 43% of IPv6 prefixes), well above the world average for IPv4 (about 65%). But networks that filter invalid routes reach only 0.34% of users, against 32% worldwide. 6% of .tt domains are signed with DNSSEC	[145]

Attacker speed against Trinidad and Tobago's response

Attacker	Trinidad and Tobago's response
The PaperCut swarm went from its first break-in to 440 compromised servers in about 45 hours [116]	Banks must notify the Central Bank within 24 hours and report within 72. The whole campaign could run its course before a bank's full report was due. That measures how fast the regulator would learn, not how fast banks respond, which is not public [64, 65]
Check Point's firewall flaw CVE-2026-85102 was fixed on 9 September and attacked from 12 September; the PaperCut flaw was attacked about four days after its advisory [116, 139]	TT-CSIRT warned about the Check Point flaw on 23 September, 11 days after attacks began. For 10 of those days the vendor had not yet confirmed exploitation either. TT-CSIRT issued no PaperCut warning [138, 139]
In 2025, criminal intruders began moving from the first compromised machine to others 29 minutes after initial access, on average [133]	No public data show how fast Trinidad and Tobago institutions detect or contain an intrusion. In a review covering January 2020 to March 2022, four of the seven banks reviewed operated a round-the-clock security operations centre; some also used an outside managed security provider, and three relied on the same one [66]
PHP2Shell (October 2026): fixed on 21 October, listed by CISA as exploited on 26 October, with attacks on firewall management screens reported on 29 October [165, 166, 171]	TT-CSIRT warned on 21 October. New York's financial regulator told its firms on 22 October to patch or disconnect. The Central Bank posted nothing on the flaws between 21 and 29 October [167, 168, 182]
Exploitation often begins before a patch exists [131]	When TT-CSIRT does warn, its advisories come a median of two to three days after the vendor or CISA [138]

Comparison of public data. Dates may differ by a day because of time zones.

TT-CSIRT is sometimes ahead. It warned about one SharePoint flaw 29 days before CISA listed it as exploited, and about the PHP2Shell flaws, the most serious of the month, on the day the fix was released, five days before CISA listed them as exploited. [138, 167] But on public evidence it works as a relay of other countries' warnings. Nothing published shows that it scans for, or receives data on, vulnerable systems inside the country.

How the next two years could unfold

The scenarios follow the Bank of England's framework [127], applied to Trinidad and Tobago. They are illustrative, not forecasts.

Scenario	What it would look like
Better	The Central Bank and TT-CSIRT push warnings within 24 hours. Banks, Infolink and the main vendors fix exploited internet-facing flaws within days and adopt phishing-resistant logins for staff. Attacks continue but stay contained within individual firms
Middle (most likely on current policy)	The large banks, backed by capital and, for the foreign-owned ones, parent groups, adapt. Credit unions, small insurers, brokers, e-money firms and local vendors fall behind. Automated sweeps hit their unpatched systems, causing outages of days to weeks, leaked customer data and more fraud. Disruption spreads through shared suppliers or telecoms
Worse	A shared provider, such as a payment switch, core-banking or IT vendor, telecom operator or cloud host, is compromised, as Ymirlink and IDC Frontier were. Several institutions are disrupted at once, and foreign-exchange limits slow the purchase of outside help

Verdict on tomorrow's swarms

On current capacity, AI agent swarms would be too much for many smaller institutions at the edges of Trinidad and Tobago's financial system, and the gap is widening. Campaigns now finish in hours or days. A national warning system that covers between one in six and one in ten exploited flaws in leading firewall, VPN and gateway products, usually days late and with no published staff, cannot keep pace. Neither can a supervisor that reported one on-site cyber examination of a bank in its latest year, or credit unions with no cyber supervisor at all.

The evidence does not show that swarms are unstoppable. In the largest documented campaign, the attackers had reached full network control at only 12 of the 395 identified victim organisations when last observed, partly because they had not yet followed up most break-ins; in at least one case a web application firewall stopped them, and the researchers conclude that basic hardening still matters. [116] The large banks, with capital, monitoring centres and, for the foreign-owned ones, parent groups, are better placed to hold. For them and for the system as a whole, swarms are not too much on current evidence, although a successful attack on shared infrastructure could change that.

More staff alone will not close the gap, because no small country can hire its way to machine speed. What closes it is applying the basics at machine speed:

- automated patching of internet-facing systems;
- automated national warnings drawn from exposure data;
- phishing-resistant logins;
- automatic holds on suspicious payments;
- round-the-clock monitoring shared by the small institutions that cannot afford their own.

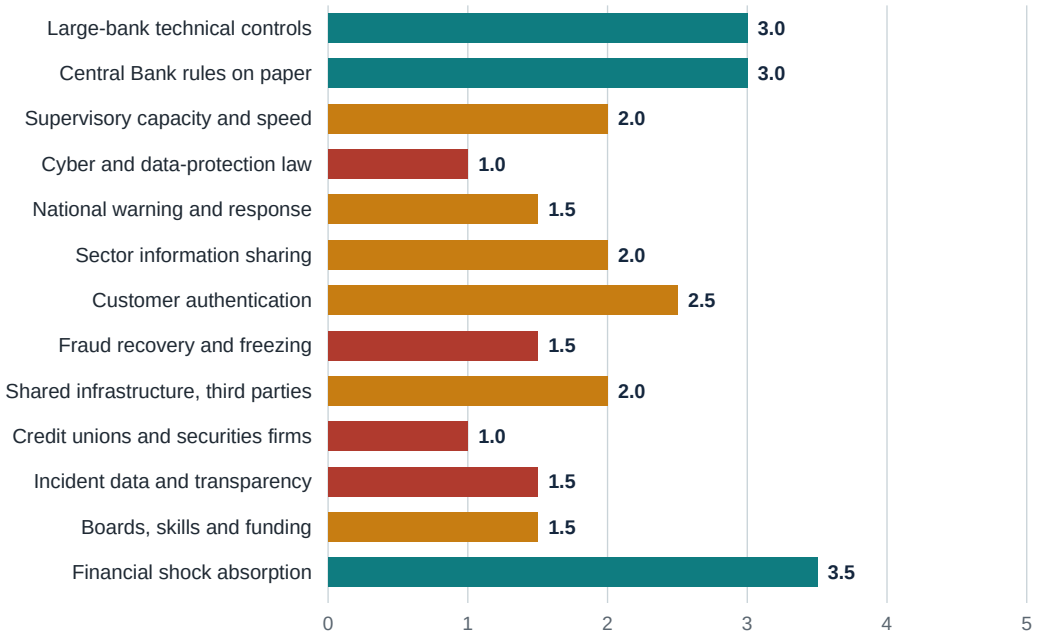
10. Readiness scorecard

Each domain is rated from 1 to 5 against the international practice described in this report: [43-45, 87-91]

- **1:** absent, or a major gap.
- **2:** early or partial.
- **3:** broadly meets a 2023-era baseline.
- **4:** largely meets current practice.
- **5:** comparable with leading jurisdictions.

The ratings are analytical judgments from public evidence and are not weighted. **The scorecard mainly measures the framework around institutions**: law, supervision, data and shared arrangements, plus what institutions disclose. It does not measure tested defensive capability, which public sources cannot show.

Readiness scorecard | 1 = absent or major gap, 3 = 2023-era baseline, 5 = leading practice



Domain	Rating	Basis
Technical controls at the largest banks	3.0	International frameworks, 24x7 monitoring and, for foreign-owned banks, parent-group programmes reported; app-based login codes at RBC; SMS codes and limited payee verification persist; First Citizens discloses little [54, 66, 83, 146]
Central Bank rules on paper	3.0	24/72-hour reporting since 2023, self-assessment and testing expectations; key controls only "recommended"; AI named as a supervisory risk but absent from the cyber guideline [64, 65, 67]
Supervisory capacity and speed	2.0	Self-assessments, incident reporting, an e-fraud survey and examiner training; but one joint cyber examination in a year, an unpublished framework, no public response to frontier AI and no public communication on the October 2026 PHP flaws [62, 67, 68, 182]
National cyber and data-protection law	1.0	Cybercrime bill lapsed; data-protection obligations unproclaimed; no breach-notification law [73, 74]
National warning and incident response	1.5	Real operational capacity; but no legal mandate, no published staffing or hours, not in FIRST, a 169-day publication gap, and warnings on only 13 of 222 actively exploited flaws in 2026, although it warned on PHP2Shell the day the fix appeared [77, 79, 138, 140, 167]
Sector information sharing	2.0	Industry committees, a Central Bank-convened fraud group and regional agreements; no formal local platform [62, 66, 69, 85]
Customer authentication and payment controls	2.5	Multi-factor login is common and some banks offer tokens or app approval; SMS codes remain widely used or selectable; no confirmation of payee described [83]
Fraud recovery and cross-border freezing	1.5	Coordination began with the Central Bank's October 2025 meeting, but no protocol has been published; a business chamber called for one in 2026 [56, 69]
Shared infrastructure and third parties	2.0	New payment licensing standards; incumbent switch's resilience unpublished; concentration noted [66, 70]
Credit unions and securities firms	1.0	No credit-union prudential or cyber supervisor; no securities cyber guideline; a credit union hit by ransomware. Insurers fall under the Central Bank's rules and are scored with them [51, 58, 81, 95]

Domain	Rating	Basis
Incident data and transparency	1.5	TT-CSIRT publishes counts of voluntarily reported incidents, but private firms rarely report, the Central Bank publishes nothing from its own reporting regime, police series conflict and no loss data exist [57, 77, 99]
Boards, skills and funding	1.5	Board skill gaps; security reporting to IT at CIBC Caribbean and at the Central Bank; staff shortages and a small skills pipeline; lapsed tax allowance; an IDB-backed cybersecurity component not yet spent on cyber; foreign-exchange constraints [62, 71, 76, 82, 84, 141, 144]
Financial shock absorption	3.5	Strong capital, chip cards and a cash fallback; but a narrowing liquidity buffer, heavy sovereign exposure and foreign-exchange pressure [62, 71]
Unweighted average	**2.0**	**Not ready for a determined AI-assisted group; partly ready for routine crime**

The result is not sensitive to individual judgments: moving any five domains by half a point in either direction changes the average by about 0.2.

The pattern is clear. Defences are strongest where capital rules and, for foreign-owned banks, parent-group programmes do the work. They are weakest wherever national government action is required.

How Trinidad and Tobago compares with two Caribbean peers

Measure	Trinidad and Tobago	Barbados	Jamaica
Bank incident-reporting clock	24-hour notice and 72-hour report (since 2023) [64, 65]	Classify within 24 hours; initial report within 4 hours of classifying an incident as major [87]	72 hours [88]
AI addressed in cyber rules	No; AI is named only as a general supervisory risk [64, 67]	Yes: AI and machine-learning section (March 2026) [87]	Not reviewed
Required penetration testing	Testing "commensurate" with risk; threat-led testing "where necessary and appropriate" [64]	Annual tests of internet-facing systems; full-scope tests every two years; threat-led testing [87]	Annual tests; full-scope tests every two years [88]
Sector threat-sharing platform	None found [66, 85]	Not reviewed	Yes, established 2025 [88]
Public frontier-AI response (BIS list)	No [44]	No [44]	No [44]

Selected measures only; "not reviewed" means this research did not establish the position, not that the measure is absent.

Trinidad and Tobago's bank reporting clock is comparable with its neighbours'. Barbados has moved further on testing and AI-specific rules, and Jamaica on testing and information sharing.

11. How an AI-armed group would most likely attack, and what would happen

The question is not whether a group could break into Trinidad and Tobago's best-defended bank core. It is which route a rational attacker would choose, and how the system would respond. The table describes likely routes at a strategic level only.

Attack route	Why it fits T&T	Likelihood (12 months)	Impact	Readiness
Impersonated or deepfaked executive orders urgent payments	Already happened at CIBC (2025); deepfakes of ministers are common; Fideuram shows the AI version	High	Millions of dollars per case; reputational damage	Low to medium: depends on each bank's call-back rules; no sector standard
AI-written phishing, texts and calls lead to account takeover via stolen codes or SIM swaps	Phishing and email compromise account for 296 of the 485 incidents reported to TT-CSIRT since 2019; SMS codes are widespread; TSTT leak data exist	High	Many individual losses, with elderly customers a particular concern; erosion of trust	Low
Rapid exploitation of an unpatched internet-facing system at a credit union, insurer, broker or vendor, followed by ransomware or extortion	Venture Credit Union and insurers already hit; the Korean "side-door" pattern; national advisory gaps	High	Outages lasting days to weeks; data leaks	Low
Deepfake or synthetic identities used to open accounts for laundering	FIUTT reports a rise in onboarding fraud; digital account opening is spreading [58]	Medium to high	Laundering; damage to international standing	Low: FIUTT's advisory does not address liveness or deepfake detection
Automated sweep by AI agents exploiting a newly published flaw in internet-facing software at many organisations at once	The PaperCut campaign, exploited about four days after the vendor's advisory; the October 2026 PHP2Shell wave; national warnings cover few exploited edge flaws	High	Many simultaneous incidents at weaker firms; outages and data leaks	Low
Breach of a vendor that sends customer emails or texts, hosts systems or monitors security for several institutions	Ymirlink and IDC Frontier in Japan; local institutions outsource these services	Medium	Customer data exposed across institutions, followed by tailored phishing	Low: no public rule on how fast vendors must report breaches
Compromise of a shared provider such as a payment switch, core vendor, security provider or telecom	Infolink concentration; the JETS breach; three banks sharing a security provider	Low to medium	Potentially system-wide	Unknown; low on public evidence
AI-assisted intrusion into a large bank's core network	GTG-1002 targeted financial institutions; AI lowers the cost of trying	Low to medium	High	Medium
Politically motivated disruption linked to regional tensions	Venezuela-related tensions since 2025	Low	Medium to high	Low to medium

Likelihood and impact are analytical judgments, not probabilities. Readiness reflects public evidence only.

The most likely damage is not a single dramatic heist. It is a steady and probably rising flow of impersonation fraud and account takeovers, with occasional ransomware at the periphery, each individually survivable. Together they drain customers, burden police and erode confidence in digital banking just as the CBTT plans an instant-payment system and a fully digital payments system by 2035. [70]

The tail risk is an outage at shared infrastructure. A multi-day failure of the ACH or the LINX network would interrupt salaries, bill payments and card transactions across all participating banks. The cash fallback would limit, but not eliminate, the harm. Abroad, ransomware took a US$9 billion California credit union's online banking offline for more than two weeks, and customers reported ATM withdrawals limited to US$500. [97] A similar event at a large local credit union or insurer is plausible.

12. What would make Trinidad and Tobago ready

Most of the required measures are rules and coordination, not expensive technology. The binding constraints are political priority, legislative time and specialist staff.

Within three months: no new legislation needed

Action	Responsible	Why
Issue a frontier-AI supervisory letter requiring accelerated patching of internet-facing systems, inventories of exposed devices, tested backups and board briefings	CBTT, TTSEC	At least eleven, mostly advanced-economy, jurisdictions issued letters, statements, inspections or task forces in 2026, mostly asking firms to apply existing controls faster [44, 89, 90]
Set a sector standard for payment instructions: independent call-back verification for urgent, executive or new-beneficiary payments above a threshold; no approval on WhatsApp or email alone	CBTT with BATT	Directly targets the CIBC and Fideuram pattern [19, 53, 92]
Create a 24/7 rapid fraud-freeze protocol among banks, police and FIUTT, including templates for cross-border recall requests	CBTT, BATT, TTPS, FIUTT	Singapore and Hong Kong police recovered essentially all of a US$499,000 deepfake-induced transfer through fast cross-border cooperation [20]; a local business chamber has asked for exactly this [56]
Publish aggregate incident and fraud statistics	CBTT, TT-CSIRT, TTPS	Turns anecdotes into evidence and lets progress be measured
Require an enforced DMARC email policy (reject, or quarantine as a first step) on every domain used to contact customers, within 90 days	CBTT and TTSEC for their licensees; TATT for telecoms; the Credit Union League to press credit unions until a supervisor exists	15 of 33 institutions checked do not enforce it; US federal agencies have had to since 2018 [161]
Warn within 24 hours on every flaw CISA lists as actively exploited in common internet-facing products, and use free national exposure feeds to alert the owners of vulnerable systems directly	TT-CSIRT	2026 coverage was about 6% of listed flaws, and warnings came days after attacks began [138, 139]
When a flaw is being mass-exploited, issue a same-day instruction to licensees to patch or disconnect affected internet-facing systems, and publish it	CBTT, TTSEC	New York's regulator did this within a day for PHP2Shell; the Central Bank published nothing [168, 182]
Agree in advance when banks, Infolink and key vendors would take public services offline during an attack, including shared and cloud systems	CBTT with banks and Infolink	Japan's regulators asked for this in May 2026; the FEC had to shut down mid-attack [103, 114]
Require vendors that hold customer data or send customer messages to report a suspected breach to the institution within 24 hours	CBTT, TTSEC	Japanese banks announced 11 days after their email vendor detected its breach [106, 107]

Within twelve months

- **Law:** enact a modern cybercrime law and proclaim the Data Protection Act with mandatory breach notification. Give TT-CSIRT a statutory mandate, published staffing and hours, a 24/7 contact, a budget line and membership of FIRST.
- **Customer authentication:** require phishing-resistant MFA for staff privileged and remote access. Phase out SMS codes for high-risk customer actions such as adding a payee, raising limits or changing devices. Build confirmation of payee into the planned instant-payment system before launch, not after.

- **Patching:** set deadlines for actively exploited, internet-facing vulnerabilities measured in days rather than "commensurate" timeframes.
- **Sharing:** build a sector threat-sharing hub on Jamaica's model, covering banks, insurers, credit unions, Infolink and the telecom operators. [88]
- **Testing:** require threat-led penetration testing for the systemically important banks and Infolink. Apply the new payment-infrastructure cyber standards to incumbent operators.
- **Periphery:** bring credit unions under prudential and cyber supervision. Fund pooled round-the-clock monitoring and response for small credit unions, insurers and e-money firms that cannot afford their own, for example through the Credit Union League or a shared provider.
- **Telecoms:** have TATT require SIM-swap controls and a way for banks to check whether a SIM was recently changed before trusting an SMS code.
- **Defensive AI:** seek access to AI developers' defensive programmes jointly, through CARICOM bodies or Caribbean central banks, because developers favour partners whose systems serve far more people than any one small country has. Use AI for fraud detection and patch prioritisation.
- **Exercises:** run a sector-wide exercise that combines ransomware at a shared provider with deepfake payment fraud, and publish the lessons.

13. What to monitor, and the final judgment

Indicator	Why it changes the assessment
A CBTT or TTSEC communication on frontier AI	The clearest signal that supervisors have registered the 2026 shift
Publication of the 2025 Financial Stability Report with incident counts	Tests whether the Central Bank will publish regular counts from its own incident-reporting regime
A cybercrime bill tabled; Data Protection Act proclaimed with breach notification	Determines whether the national framework moves at all
Private-sector reports to TT-CSIRT, and timely advisories on exploited edge devices	Measures national visibility and early warning
Credit-union supervisory legislation	Closes the largest unsupervised segment
Findings on Jamaica's JETS breach (a minister set JETS a 31 October 2026 deadline for a written report; publication is not assured) [102]	Would show how a regional payment switch was entered and what Infolink should check
Bank authentication changes: SMS phase-out, confirmation of payee	Shows whether customer-facing defences are adapting
Police fraud values and ransomware listings	Shows whether the attack volume is rising or being contained
Any attributed AI-enabled incident in the Caribbean	Converts a projected threat into a demonstrated one
TT-CSIRT's coverage of CISA-listed exploited flaws (about 6% in 2026)	The simplest measure of whether national warnings are keeping pace
Enforced DMARC across institutions (18 of 33 on 29 October 2026)	A cheap, visible test of whether institutions act on basic advice
Renewal of Infolink's card-security certificate (valid to 6 November 2026) [149]	A routine check on the payment switch's controls
New open-weight model releases and AISI, CAISI or Epoch evaluations	Shows when freely downloadable models reach today's restricted frontier
Any reported PHP2Shell compromise in Trinidad and Tobago, and any Central Bank communication on it	The first local test of a machine-speed exploitation wave
Incident-response capacity: published backlogs or response times from response firms and insurers	Shows whether the reported strain on responders is real and lasting

Final judgment

On public evidence, Trinidad and Tobago's financial system is not ready for a hacker group equipped with current AI models, including freely available Chinese open-weight models. The reason is not a lack of capital or the absence of any rules. The largest banks are well capitalised and subject to a Central Bank guideline and a 24/72-hour incident-reporting rule that compare reasonably with 2023 international practice. The foreign-owned banks also draw on parent-group security programmes.

The weakness is the system around them:

- a cybercrime law from 2000 and a data-protection law left mostly unproclaimed since 2012;
- incident statistics that capture few private-sector incidents and no losses;
- a supervisor with no public response to frontier AI;
- no formal local threat-sharing platform;
- a large credit-union sector outside prudential and cyber supervision;
- customer security that still often relies on SMS codes;
- a national warning system that covered about 6% of actively exploited flaws in 2026, with no published staff.

Inside the institutions, public evidence shows two tiers. The Canadian-owned banks publish the strongest controls; the locally owned banks, credit unions, small insurers and e-money firms disclose much less, and 15 of 33 institutions checked do not enforce a basic email-authentication setting.

AI multiplies exactly these weaknesses. It makes impersonation more convincing, scanning cheaper and exploitation faster. Open-weight models remove one external check: the AI developer's ability to spot and stop misuse, which so far has worked mainly after the fact.

The evidence does **not** show that a successful AI-driven attack on a local bank has occurred, that open-weight models outperform US models, or that a systemic cyber crisis is imminent. Losses to date have been material but not systemic, and strong capital and a cash fallback limit the damage to the financial system itself. Nor can public evidence show how well individual banks would hold up. Determined groups have breached financial institutions in far larger and better-resourced systems, so readiness is a matter of degree everywhere.

The appropriate conclusion is a large and widening readiness gap in the framework around the financial system. The cheapest fixes are regulatory and organisational, and could begin within weeks. Every month without them leaves attackers' falling costs to meet defences that are changing only slowly. With capability doubling every four to five months and freely downloadable models less than a year behind, the window to act before swarm-scale attacks reach the periphery is short. The October 2026 PHP2Shell wave was a live test. TT-CSIRT warned on the day, but the Central Bank said nothing publicly, while supervisors abroad told firms within a day to patch or disconnect.

Sources, methods and verification

Evidence boundaries

The report uses public research, official statistics, regulator and parliamentary documents, company disclosures, and threat reports from AI developers and security firms. Research was completed on 28 October 2026 and extended on 29 October 2026. No institution was contacted, tested or given an opportunity to comment, and no confidential supervisory information was available. Absence of a public incident does not mean absence of an incident: ransomware victims who pay are often not listed, and there is no general breach-notification duty.

Several source types have interests to weigh:

- AI developers' threat reports (Anthropic, OpenAI, Google) describe misuse of their own products, and the developers compete commercially with Chinese labs.
- Security vendors sell defensive products.
- Government evaluators frame some findings in terms of US-China competition.
- Criminal-market prices and victim counts are often self-reported by attackers.

Figures reported in different currencies or without a stated currency are given as published. Local police and court figures reported in dollars are taken to be Trinidad and Tobago dollars, following local convention. The CIBC loss is reported without a currency. Where sources conflicted, the report uses the primary source and notes the conflict.

TT-CSIRT's incident counts were read on 28 October 2026 from the data embedded in its statistics page, which draws the figures with scripts. A plain download of the page shows only empty placeholders.

Passive internet checks (Section 8). On 29 October 2026 the research looked up public DNS records for 49 domains: 37 belonging to 33 Trinidad and Tobago institutions and public bodies, five belonging to foreign parent groups and seven belonging to foreign comparators. It read each domain's mail servers and its SPF, DMARC and DNSSEC settings through a public DNS resolver. It then made one ordinary web request to each home page, to read whether the site sends an HSTS header, and one to the standard location of a security.txt file. This is the information every email server and web browser receives. Nothing was scanned, probed or logged into. Where an institution uses several domains, the one that receives its email was counted. Results for individual institutions are held privately for notification to them.

National warning coverage (Section 9). CISA's catalogue of known exploited vulnerabilities (version of 28 October 2026) was compared with every vulnerability identifier named in TT-CSIRT's published posts from 13 March 2026, when it resumed publishing, to 28 October 2026. "Eight leading firewall, VPN and gateway vendors" means Citrix, Fortinet, Ivanti, SonicWall, Palo Alto Networks, Check Point, F5 and Zyxel; some of their listed products are not edge devices. Including Cisco, coverage was 5 of 48. Timing comparisons use publication dates and may differ by a day because of time zones.

The research and fact-checking for this report were carried out with the help of AI research agents built on Anthropic's Claude models. Anthropic's own threat reports and model evaluations are among the sources. Factual claims were checked against their cited sources in independent verification passes, and the conclusions are the author's.

Calculation conventions

Calculation	Definition
ACH value per business day	TT$182.7bn / 250 business days = approximately TT$730m. The business-day count is an assumption.
Credit-union share	TT$18.5bn estimated credit-union assets / TT$166.6bn commercial-bank assets = approximately 11%. Both figures are for 2025, but the credit-union figure is a CBTT estimate unchanged since 2021.

Calculation	Definition
TT-CSIRT totals	23 + 52 + 35 + 43 + 52 = 205 for 2019-2023, matching the Central Bank's figure; adding 118 (2024), 91 (2025) and 71 (to 23 July 2026) gives 485.
Global Cybersecurity Index total	Sum of five ITU pillar scores: 8.88 + 6.98 + 16.21 + 13.03 + 11.13 = 56.23.
Korean deficiency share	130 / 555 firms = 23.4%.
Fraud Squad change	$167.37m / $51.15m - 1 = +227%.
Scorecard average	Unweighted mean of 13 domain ratings = 26 / 13 = 2.0. The 28 October draft scored 27 / 13 = 2.1; national warning and boards, skills and funding were each lowered by 0.5 on the new evidence in Sections 8 and 9.
DMARC totals	33 institutions: 18 enforce (quarantine or reject), 10 monitor only (none), 5 have no record; 18 + 10 + 5 = 33.
National warning coverage	13 of 222 CISA additions = 5.9%, about 6%; 5 of 32 additions for eight leading edge vendors = 15.6%, about one in six; 5 of 48 including Cisco = 10.4%, about one in ten.
FEC outage length	About 22:00 on 26 October (22:15 on the status page) to 16:50 on 28 October (US Eastern) = about 43 hours.
Scorecard sensitivity	Five domains x 0.5 points / 13 domains = about 0.2 change in the average.

Scorecard method

Domains were chosen to cover the controls that international authorities emphasised in 2026: governance, patching speed, authentication, response and recovery, third-party concentration, information sharing and incident reporting. Ratings compare public evidence on Trinidad and Tobago with the practices in the cited international and regional sources. Missing information counts against a domain only where the missing item is itself a control, such as a published statistic or a written rule. The scorecard therefore measures the framework and what is disclosed, not tested defences. A different weighting, or confidential evidence, could change individual ratings. It is unlikely to change the overall conclusion, which rests on documented gaps in law, data and supervisory response.

References: AI-enabled attacks and the global threat

[1] Microsoft Threat Intelligence (14 February 2024), *Staying ahead of threat actors in the age of AI*, research with OpenAI; Infosecurity Magazine coverage. Microsoft · Infosecurity Magazine.

[2] Anthropic (27 August 2025), *Detecting and countering misuse of AI*. Report.

[3] Anthropic (13 November 2025), *Disrupting the first reported AI-orchestrated cyber espionage campaign*. Report.

[4] Anthropic (3 June 2026), *What we learned mapping a year's worth of AI-enabled cyber threats*. Report.

[5] Anthropic (September 2026), *Detecting and countering misuse of AI: September 2026*. Report.

[6] OpenAI (October 2025), *Disrupting malicious uses of AI*. Report.

[7] Google Threat Intelligence Group (5 November 2025), *Advances in threat actor usage of AI tools*. Report.

[8] Google Threat Intelligence Group (May 2026), *Adversaries leverage AI for vulnerability exploitation, augmented operations, and initial access*. Report.

[9] Google Threat Intelligence Group (8 September 2026), *From prompting to autonomy*. Report.

[10] BleepingComputer (July 2025), CERT-UA's disclosure of LAMEHUG malware using Qwen. Article.

[11] Check Point (2 September 2025), *HexStrike-AI: when LLMs meet zero-day exploitation*. Report.

[12] Palo Alto Networks Unit 42 (30 July 2026), *Chinese-speaking threat actor harnesses AI models for autonomous cyberattacks*. Report.

[13] Gambit Security (22 September 2026), autonomous AI agents compromising online retailers for about US$25 per target. Interim vendor report. Report.

[14] CrowdStrike (7 October 2026), *Unknown threat actor uses AI-driven ARTEX to target South Korean finance*. Moderate-confidence attribution. Report.

[15] Korea Times (14 October 2026), *AI-driven cyberattacks hit 16 financial firms, expose 100,000 records*. Article.

[16] American Banker (October 2026), *AI-linked hacks hit Korean banks through loan-agent sites*. Article.

[17] Straiker (21 October 2026), *Inside CARLIY0S*. Counts targets, not compromises. Report.

[18] CNN (16 May 2024), Arup deepfake loss in Hong Kong. Article.

[19] Sky TG24 (25 September 2026) and Private Banker International (28 September 2026), Fideuram voice-clone fraud. Details from unnamed sources. Sky TG24 · Private Banker International via Yahoo Finance.

[20] Singapore Police Force (7 April 2025), recovery of funds from a deepfake video-call scam with Hong Kong police. Release.

[21] Heiding, F., Schneier, B. et al., *Evaluating large language models' ability to automate spear phishing*. Controlled study, 101 participants. Paper page.

[22] Verizon (19 May 2026), *2026 Data Breach Investigations Report*. Release.

[23] Sullivan & Cromwell (April 2026), Treasury Secretary and Federal Reserve Chair warn bank CEOs about Mythos cyber risks. Memo.

[24] Google Threat Intelligence Group (June 2025, updated), *The cost of a call: from voice phishing to data extortion*. Report.

[25] FBI (26 February 2025), *North Korea responsible for US$1.5 billion Bybit hack*. Public service announcement.

[26] The Record (July 2025), Brazil police arrest IT worker over C&M Software theft. Article.

[27] EVERTEC (September 2025), Form 8-K on the Sinqia incident. Filing.

[28] CISA and partners (27 August 2025), advisory AA25-239A on Chinese state-sponsored network compromise; CISA (December 2024) mobile communications guidance. Advisory · Mobile guidance.

[29] Recorded Future (2 April 2026), *Latin America and the Caribbean cybercrime landscape*. Report.

[30] Check Point (October 2026), *September 2026 cyber threat landscape*. Vendor telemetry. Report.

[31] Al Jazeera (28 October 2025), Venezuela declares Trinidad and Tobago's prime minister persona non grata. Article.

[32] SecurityWeek (January 2026), reports on cyber operations' role in the Maduro capture. Article.

References: AI model capability and policy

[33] UK AI Security Institute (13 April 2026), *Our evaluation of Claude Mythos Preview's cyber capabilities*. Blog.

[34] UK AI Security Institute (17 July 2026), *How far behind the frontier are leading open weight models on cyber?* Blog.

[35] UK AISI and US CAISI (23 July 2026), *Preliminary assessment of Kimi K3's cyber capabilities*. Assessment.

[36] NIST CAISI (17 September 2026), *Assessment of Z.ai's GLM-5.3 cyber capabilities*. Assessment.

[37] NIST CAISI (30 September 2025), *Evaluation of DeepSeek AI models finds shortcomings and risks*. Release.

[38] NIST CAISI (1 May 2026), *Evaluation of DeepSeek V4 Pro*. Release.

[39] Cisco (31 January 2025), *Evaluating security risk in DeepSeek and other frontier reasoning models*. Blog.

[40] Anthropic (29 September 2026), *GLM-5.3 and the spread of advanced cyber capabilities*. Commercial competitor's assessment. Research.

[41] RAND (2026), human uplift study of frontier AI for offensive cyber operations, and follow-up on AI agents. Report.

[42] Flare (20 October 2026), *AI models are fueling a new wave of cybercrime: a quantitative analysis*. Report.

[43] Bank for International Settlements (20 July 2026), *A Mythos moment? Frontier AI and cyber risk*, BIS Bulletin No 129. Bulletin.

[44] BIS Financial Stability Institute (September 2026), *When machines attack: frontier AI cyber threats and policy responses in the financial sector*, Occasional Paper No 28. Paper.

[45] Financial Stability Board (28 August 2026), Chair's letter to G20 Finance Ministers and Central Bank Governors on frontier AI. Letter.

[46] Anthropic (2 June and 6 October 2026), *Expanding Project Glasswing* and *Cyber Verification Program*. Glasswing expansion · Cyber Verification Program.

References: Trinidad and Tobago incidents and fraud

[47] The Record (May 2022), *Trinidad's largest supermarket chain crippled by cyberattack*; TechNewsTT (September 2022) on the Hive group's claim. The Record · TechNewsTT.

[48] The Record (July 2023), *Trinidad and Tobago hit with cyberattack*. Article.

[49] Trinidad Express (February 2024), *Report: hackers accessed TSTT using admin's credentials*; TSTT update (3 November 2023). Express · TSTT.

[50] The Record (December 2023), *Trinidad and Tobago social security agency hit with post-Christmas ransomware attack*. Article.

[51] TechNewsTT (August 2025), *Venture Credit Union announces recovery from ransomware attack*. Article.

[52] Computer Forensics and Security Institute (CFSI), Caribbean ransomware reports for 2024, 2025 and January-June 2026; TechNewsTT on 2023 data. Leak-site listings, anonymised; the author's firm sells security services. 2024 · 2025 · H1 2026 · 2023 · TechNewsTT, April 2026, on breaches beyond listings.

[53] Trinidad Guardian (July 2025), *Online scammers steal millions from CIBC T&T*. Article.

[54] CIBC Caribbean Bank (December 2025), *Annual Report 2025*: Chair's message and cyber disclosures. Annual report.

[55] Trinidad Guardian (March 2026), *Malware attack delays National Quarry financials*. Article.

[56] Trinidad Express (16-17 July 2026), *Businessman questions bank after $1m cyber theft*. Victim's account. Article.

[57] Trinidad Express (26 August 2026), *Fraud Squad gets fewer reports but losses rise 227%*. Article.

[58] FIUTT (March 2026), *Annual Report 2025*; Advisory ADV/003/2025 on onboarding fraud (8 December 2025). Annual report · Advisory.

[59] TTSEC (April 2026) and Ministry of Finance (15 June 2026), public advisories on deepfake videos. TTSEC · Ministry of Finance.

[60] Trinidad Express (November 2025), *$30M scam: inside the collusion between bank staff and car dealers*. Article.

[61] Trinidad Guardian (October 2025), *Rising online fraud worries Central Bank*. Article.

References: Trinidad and Tobago regulation, law and structure

[62] CBTT (September 2025), *Financial Stability Report 2024*. Report.

[63] CBTT (September 2024), *Financial Stability Report 2023*. Report.

[64] CBTT (September 2023), *Cybersecurity Best Practices Guideline for Financial Institutions*, especially Section 3 and Appendix II. Guideline.

[65] CBTT circulars CB-OIFI-399/2025, *Mandatory cybersecurity incident reporting* (5 February 2025), and CB-OIFI-450/2025 on annual self-assessments (11 February 2025). Incident reporting · Self-assessment.

[66] CBTT (August 2022), *Report on the thematic review of commercial banks' cybersecurity risk management practices*. Report.

[67] CBTT (May 2026), *Annual Report 2025*; *Annual Report 2024* (December 2025); risk-based supervision framework effective 1 October 2025. Annual report 2025 · Annual report 2024 · Framework.

[68] CBTT (October 2026), *Strategic Plan 2026/27-2030/31: Insight to Impact*. Plan.

[69] CBTT (28 October 2025), *Central Bank leads collaborative efforts to tackle online banking fraud*. Release.

[70] CBTT, *Licensing procedures for payment system operators* (effective 29 September 2026), *Payment system landscape* and *Payment services* registers; Infolink Services, *About us*; CBTT working paper WP04/2026 on instant payments. Licensing · Landscape · Payment services · Infolink · WP04/2026.

[71] CBTT, *Economic DataPack* (September 2026) and *Monetary Policy Report* (May 2026). DataPack · MPR.

[72] *Financial Institutions Act*, Chap. 79:09, sections 10, 12 and 86. Consolidated text.

[73] Parliament of Trinidad and Tobago, *The Cybercrime Bill, 2017* and bills of the 13th Parliament. Cybercrime Bill · Bills list.

[74] *Data Protection Act*, Chap. 22:04, proclamation status; Senate Hansard (21 April 2026). Legislation library · Hansard.

[75] Senate Hansard (29 October 2025), motion on the growing threat of deepfake technology. Hansard.

[76] Ministry of Finance, *Budget Statement 2026* (13 October 2025) and *Budget Statement 2027* (12 October 2026); *Finance Act 2026*. Budget 2026 · Budget 2027 · Finance Act 2026.

[77] TT-CSIRT, *National cyber security documents*, *Statistics*, and posts and advisories feed. Documents · Statistics · Regional collaboration.

[78] ITU (September 2024), *Global Cybersecurity Index 2024*, country profile. Report.

[79] e-Governance Academy, *National Cyber Security Index: Trinidad and Tobago* (updated April 2025). Index.

[80] TATT (30 January 2026), *Cybersecurity framework for public telecommunications networks*; *Annual market report 2025*. Framework · Market report.

[81] IMF (June 2024), *Trinidad and Tobago: 2024 Article IV Consultation*. Report.

[82] Arthur Lok Jack Global School of Business (January 2025), *Assessing the readiness of Caribbean boards for effective cybersecurity oversight*. Caribbean-wide, all sectors. Study.

[83] Banks' customer security pages and disclosures, viewed October 2026: Republic Bank, Scotiabank Trinidad and Tobago, CIBC Caribbean and ANSA Bank; Republic Financial Holdings *Annual Report 2025*. Republic · Scotiabank · CIBC Caribbean · ANSA Bank · RFHL.

[84] First Citizens Group Financial Holdings (January 2026), *Annual Report 2025*, Appendix 1 skills matrix. Annual report.

[85] Bankers Association of Trinidad and Tobago, *About*. Page.

[86] CIBC Caribbean Bank (28 May 2026), notice of material change on the Butterfield transaction. Notice.

References: international and regional benchmarks

[87] Central Bank of Barbados (revised 31 March 2026), *Technology and cyber risk management guideline*. Guideline.

[88] Bank of Jamaica, *Standard of sound practice on the management of cyber risks* (2024); *Financial Stability Report 2025*; statement on the cyber incident at JETS Limited (23 October 2026). Standard · FSR 2025 · JETS statement.

[89] New York Department of Financial Services: industry letters of 21 May 2026 on frontier AI and on heightened-threat measures; 16 October 2024 letter on AI cyber risks; 23 NYCRR Part 500. Frontier AI · Heightened-threat measures · AI risks 2024 · Part 500.

[90] Bank of England, FCA and HM Treasury (15 May 2026), *Joint statement on frontier AI models and cyber resilience*. Statement.

[91] IMF (April 2024), *Global Financial Stability Report*, Chapter 3, *Cyber risk: a growing concern for macrofinancial stability*. Chapter.

[92] FS-ISAC (October 2024), *Deepfakes in the financial sector: understanding the threats, managing the risks*. Paper.

[93] ICT Pulse (January 2026), summary of the 2025 IDB-OAS cybersecurity maturity report for the Caribbean. Summary.

[94] OSFI (April 2026, modified July 2026), *Technology risk bulletin: frontier artificial intelligence*. Bulletin.

[95] TTSEC (7 July 2023), circular on the enhanced risk-based supervision framework. Circular.

[96] BIS Financial Stability Institute (June 2023), *Banks' cyber security: a second generation of regulatory approaches*, FSI Insights No 50. Paper.

[97] The Record (2024), Patelco Credit Union ransomware and data breach. Article.

[98] Trinidad Express (13 October 2026), *Budget success hinges on execution and policy clarity*, including the Bankers Association's budget response. Article.

[99] Trinidad and Tobago Police Service, *Crime statistics* (2025 data; fraud offences by month). Statistics.

[100] CBTT (23 April 2026), *Understanding cyber threats and financial fraud to stay one step ahead*, public session with BATT and TTSEC. Notice.

[101] CISA and partners (29 July 2025), updated joint advisory on the Scattered Spider group. Alert.

[102] Jamaica Observer (27 October 2026), *Wheatley demands info on MultiLink breach*. Article.

References: the latest attacks (Section 2)

[103] Reuters, syndicated by WHTC (27 October 2026), *Hackers target US Federal Election Commission system, disrupting campaign finance disclosures days before midterms*; Newsweek (27 October 2026), *Federal Election Commission offline after hacking attempt*. Reuters via WHTC · Newsweek.

[104] Federal Election Commission, status page: electronic filing system outage, 26-28 October 2026. Status page.

[105] FBI and CISA (16 October 2026), *Cyber threat actors use a variety of techniques to target election and campaign officials*, PSA I-101626-PSA. Public service announcement.

[106] Ymirlink (19, 20 and 26 October 2026), first and second reports on unauthorised access to its systems, and warning about spam sent using its domain. In Japanese. First report · Spam warning · Second report.

[107] NHK (27 October 2026), report on Resona Bank, Saitama Resona Bank and Kansai Mirai Bank; Impress Internet Watch (27 October 2026), organisations affected by the Cuenote FC breach; SmartScope summary of the Resona banks' notice (secondary; the banks' own notice blocked automated access). In Japanese. NHK · Impress · SmartScope.

[108] iBank Marketing (29 October 2026), second report on the Wallet+ email-address leak; Hachijuni Nagano Bank (19 and 29 October 2026), notices on a staff mailbox compromise and on the Wallet+ leak. In Japanese. iBank · Hachijuni, 19 Oct · Hachijuni, 29 Oct.

[109] Nomura Securities (23 October 2026), notice on a possible leak at the email contractor for its i-Port service. In Japanese. Notice.

[110] GMO Internet (23, 24 and 28 October 2026), Tokyo Stock Exchange disclosures, and 16th incident report (29 October 2026). 23 Oct · 24 Oct · 28 Oct · 16th report.

[111] Bloomberg, syndicated by Claims Journal (28 October 2026), *Trading platform rocked by Japan hack, $50 million ransom*; TechCrunch (27 October 2026), *Japan internet giant GMO says hackers posted stolen customer data*. Claims Journal · TechCrunch.

[112] The Yomiuri Shimbun via Asia News Network (October 2026), *Chinese-language AI agent may have enabled cyberattacks on Japanese firms*; Silicon UK (21 October 2026), on ARTEX attacks in Japan. Yomiuri via ANN · Silicon UK.

[113] IDC Frontier (27 October 2026, updated 28 October), seventh report: investigation results on unauthorised access. In Japanese. Report.

[114] Financial Services Agency (9 October 2026), alert on strengthening cybersecurity; FSA and Bank of Japan (22 May 2026), request on financial institutions' short-term response to frontier AI threats. In Japanese. FSA alert · FSA and BoJ request.

[115] Microsoft Security Blog (21 October 2026), *AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise*. Blog.

[116] GreyNoise (9 September 2026), *AI-orchestrated campaign against PaperCut NG/MF*. Vendor report. Report.

[117] Palo Alto Networks Unit 42 (2 September 2026), *AI-assisted cyber attack: inside a Unit 42 investigation*. Report.

[118] Security Affairs (17 October 2026), *AI agents accessed Indian organizations without authorization, CERT-In warns*, on CERT-In advisory CIAD-2026-0049. Article · Advisory.

[119] Security Affairs (12 September 2026), *Revolut exposed KYC data after fraudulent government email passed security checks*. Article.

[120] Microsoft Security Blog (10 September 2026), *Protecting organizations from AI-assisted executive impersonation and invoice fraud*. Blog.

References: AI capability, swarms and speed (Section 4)

[121] METR, *Task-completion time horizons of frontier AI models* (last updated 8 September 2026), and its Time Horizon 1.1 data file. Page · Data file.

[122] UK AI Security Institute (13 May 2026), *How fast is autonomous AI cyber capability advancing?* Blog.

[123] UK AI Security Institute (30 April 2026), *Our evaluation of OpenAI's GPT-5.5 cyber capabilities*. Blog.

[124] Epoch AI (16 October 2026), open versus closed Cyber ECI gap; Epoch AI (11 June 2026), *Are Mythos' cyber capabilities overhyped?* Data insight · Analysis.

[125] UK NCSC and Five Eyes partners (22 June 2026), *The AI shift in cyber risk: why leaders must act now*. Statement.

[126] UK NCSC (7 May 2025), *Impact of AI on cyber threat from now to 2027*. Assessment.

[127] Bank of England (July 2026), *Financial Stability Report*, Section 3; *Record of the Financial Policy Committee meeting on 25 September 2026*. FSR · FPC record.

[128] IMF (June 2026), *Artificial intelligence and cybersecurity in the financial sector*, IMF Note 2026/005. Note.

[129] UK AI Security Institute (8 July 2026), *Multi-agent AI control: distributed attacks hamper per-instance monitors*. Research.

[130] METR (26 August 2026), investigation of the OpenAI evaluation agents' attack on Hugging Face (preliminary findings); Hugging Face (27 July 2026), *Anatomy of a frontier lab agent intrusion*; SecurityWeek coverage. METR · Hugging Face · SecurityWeek.

[131] Mandiant and Google Cloud (23 March 2026), *M-Trends 2026*. Report.

[132] VulnCheck (21 January and 28 July 2026), *State of exploitation 2026* and *State of exploitation 1H 2026*. 2026 · 1H 2026.

[133] CrowdStrike (24 February 2026), *2026 CrowdStrike Global Threat Report*, press release. Release.

[134] Anthropic (22 May 2026), *Project Glasswing: an initial update*. Update.

[135] World Economic Forum with Accenture (January 2026), *Global Cybersecurity Outlook 2026*. Survey. Report.

[136] DARPA (8 August 2025), *AI Cyber Challenge marks pivotal inflection point for cyber defense*. Release.

[137] GovInfoSecurity (June 2026), *Claude Mythos 5 can build exploits but can't power campaigns*. Article.

References: Trinidad and Tobago capacity and national warnings (Section 9)

[138] CISA, *Known exploited vulnerabilities catalog* (JSON version 2026.10.28), compared with TT-CSIRT's security advisories and posts from 13 March to 28 October 2026, including advisories 429 (Citrix, July 2024) and 459 (SharePoint, July 2026). KEV catalog · TT-CSIRT advisories · Advisory 429 · Advisory 459.

[139] Check Point (22 September 2026), *Security advisory: action required: active exploitation of CVE-2026-85102 and a management pre-authentication vulnerability (CVE-2026-93616)*. Advisory.

[140] FIRST, member teams directory and public teams data (viewed 29 October 2026). Directory · Data.

[141] Ministry of Finance (12 October 2026), *Draft estimates of recurrent expenditure 2027*, *Draft estimates of development programme 2027* and *Public Sector Investment Programme 2027*. Recurrent · Development · PSIP.

[142] IDB and OAS (2025), *2025 Cybersecurity report: vulnerability and maturity challenges to bridging the gaps in Latin America and the Caribbean*. Stage ratings read from the report's charts. Report.

[143] House of Representatives Hansard, unrevised (15 May 2026), ministerial statement on strengthening the TTPS; TTT News (9 September 2026), *TTPS expands cybercrime response*. Hansard · TTT News.

[144] TTT News (18 September 2025), *UTT partners with Canadian embassy to tackle cybersecurity challenges*. Article.

[145] Internet Society Pulse, Trinidad and Tobago country report; APNIC Labs, route-origin statistics for Trinidad and Tobago (data to 28 October 2026). Pulse · APNIC Labs.

References: institutions' own disclosures and benchmarks (Section 8)

[146] RBC Royal Bank (Caribbean), *Security feature: two-factor authentication* and *RBC Security Guarantee* (Trinidad), viewed 29 October 2026; Royal Bank of Canada, *2025 Annual Report*. Two-factor · Guarantee · RBC annual report.

[147] Scotiabank Trinidad and Tobago (2026), *2025 Annual Report*, including the auditors' report. Annual report.

[148] Visa, *Global Registry of Service Providers*, entry for Republic Bank Limited (retrieved 29 October 2026). Registry.

[149] Integrity360, PCI DSS certificate for Infolink Services Limited (attestation dated 7 November 2025, valid to 6 November 2026); Infolink Services, *About us*. Certificate · Infolink.

[150] JMMB Group (2026), *Annual Report 2026*; JMMB Moneyline app listing on Google Play (updated 12 October 2026); JMMB, executive profile of the group chief information officer; Jamaica Observer (6 June 2023), *JMMB Group responds to system disruption*. App listing · CIO profile · Annual report · Observer.

[151] ANSA Merchant Bank (May 2025), *Annual Report 2024*; ANSA McAL (April 2026), *Annual Report 2025*; TechNewsTT (October 2020), *ANSA McAL reports Barbados 'security incident'*. TechNewsTT · ANSA Merchant Bank · ANSA McAL.

[152] Trinidad and Tobago Unit Trust Corporation, *Uon* portal page (viewed 29 October 2026) and *Annual Report 2025*. Uon · Annual report.

[153] National Insurance Board of Trinidad and Tobago, *Annual Report 2023-2024*. Annual report.

[154] Guardian Holdings (April 2026), *Annual Report 2025*; Sagicor Financial Company (2026), *Annual Report 2025* and *ESG Report 2025*. Sagicor ESG report · Guardian · Sagicor.

[155] Trinidad and Tobago Stock Exchange (April 2026), *Annual Report 2025*; TTSEC, *Annual Report for the year ended 30 September 2024*, published guidelines and security.txt (viewed 29 October 2026). TTSE · TTSEC annual report · Guidelines.

[156] Trinidad Guardian (11 September 2025), *Credit unions face cyber threat*; TECU Credit Union (June 2026), *Annual Report 2025*; Venture Credit Union, *Annual Report 2025* and mobile app page (viewed 29 October 2026). Venture annual report · Guardian · TECU · Venture.

[157] TechNewsTT (8 January 2024), *Ransomware's ripple effect*, section on identity theft and SIM swapping. Single first-hand account. Article.

[158] TSTT (20 October 2026), *Mausica Data Centre leads Caribbean with four international certifications*; Trinidad Guardian (25 January 2025), *TSTT hires information security officer to protect network*; Digicel Group, *Cyber security and Digicel* (viewed 29 October 2026). TSTT · Guardian · Digicel.

[159] E-money issuers' security pages, viewed 29 October 2026: WAM, PayWise, Massy Remittance (WIDiT) and Republic Bank (Endcash). WAM · PayWise · PayWise FAQs · WIDiT · Endcash.

[160] CBTT (1 July 2026), circular CB-OIFI-2207/2026 giving effect to Pillar 3 market disclosure. Circular.

[161] CISA (October 2017), *Binding Operational Directive 18-01: Enhance email and web security*. Directive.

[162] The Bank of N.T. Butterfield & Son (28 May 2026), Form 6-K on the acquisition of CIBC Caribbean, including transitional services for up to 24 months. Filing.

[163] IMF (April 2023), *Trinidad and Tobago: strengthening cybersecurity in financial institutions*, technical assistance high-level summary. Summary.

[164] Citi, *Global presence: Trinidad and Tobago* (viewed 29 October 2026). Page.

References: late October 2026 developments (Section 2)

[165] PHP project (21 October 2026), release announcements for PHP 8.5.12, 8.4.27, 8.3.36 and 8.2.35; Calif, *PHP2Shell* write-up; Help Net Security (21 October 2026), quoting Wiz. PHP · Calif · Help Net Security.

[166] CISA (21 October 2026), *Critical vulnerabilities in PHP require immediate patching*; CISA (26 October 2026), addition of CVE-2026-109618 and CVE-2026-109619 to the known exploited vulnerabilities catalog. Alert · KEV addition.

[167] TT-CSIRT (21 October 2026), advisory 462.21.10.26, *Critical remote code execution vulnerabilities in PHP (CVE-2026-109618 and CVE-2026-109619)*. Advisory.

[168] New York Department of Financial Services (22 October 2026), industry letter on patching the PHP vulnerabilities. Letter.

[169] UK NCSC (21 October 2026), *Critical security issue affecting PHP*; The Register (22 October 2026), on UK government services taken offline. NCSC · The Register.

[170] Jiji Press via Nippon.com (22 October 2026), on Japanese banks' precautionary suspensions; American Banker (23 October 2026), *Banks dodge early damage from PHP2Shell flaws*. Nippon.com · American Banker.

[171] Palo Alto Networks, security advisory for CVE-2026-109618 (updated 29 October 2026); CrowdStrike (23 October 2026), *Obstacles to weaponizing PHP2Shell likely constrain exploitation*; The Hacker News (October 2026), on confirmed exploitation; Delft University Threat Intelligence Lab, PHP2Shell tracker (viewed 29 October 2026). Palo Alto Networks · CrowdStrike · The Hacker News · Tracker.

[172] George Kurtz, CrowdStrike chief executive: CNBC interview (23 October 2026), as reported by 24/7 Wall St.; *The Compound and Friends* podcast (26 October 2026) and *Mad Money* (26 October 2026), as reported by Yahoo Finance. The *Mad Money* quote is from secondary reporting. CrowdStrike shares rose 8.25% on 23 October. 24/7 Wall St. · Podcast · Mad Money.

[173] Sophos (26 October 2026), *The breachpocalypse is here*; Dataminr (27 October 2026), *Examining the vulnpocalypse and defensive responses*, which calls reports of saturated response firms anecdotal. Sophos · Dataminr.

[174] Arctic Wolf (27 October 2026), *2026 Agentic Security Operations Report*, press release; Coveware by Veeam (28 October 2026), *Cyber extortion payment trends Q3 2026*. Arctic Wolf · Coveware.

[175] Fortune (21 October 2026), *Powerful new AI models are powering a growing wave of cyber attacks, experts say*, citing Reuters. Article.

[176] Polymarket status page (29 October 2026); The Block (29 October 2026); Hudson Rock (InfoStealers, 29 October 2026), on the third-party script; BleepingComputer (June 2026), on the earlier vendor compromise. Status page · The Block · Hudson Rock · BleepingComputer.

[177] Military Times (24 September 2026) and TIME (29 September 2026), on the Defense Manpower Data Center breach; Federal News Network (October 2026), on the lawsuit; Reuters, syndicated by KELO (29 October 2026), on commissary freezer failures; Stars and Stripes (30 September 2026), on the agency's earlier explanation. Military Times · TIME · Federal News Network · Reuters via KELO · Stars and Stripes.

[178] Fortune (29 October 2026), *"The attackers are winning": Cyber 60 founders say AI is giving hackers the upper hand*; Lightspeed Venture Partners, *Cyber 60 2026-2027* and CISO survey (Wakefield Research, 200 US CISOs, 4-14 September 2026). Fortune · Lightspeed.

[179] Banque de la République d'Haïti (19 October 2026), public notice; The Haitian Times (21 October 2026), *Capital Bank Haiti resumes services, online banking down*. In French and English. Notice · Haitian Times.

[180] CrowdStrike (21 October 2026), *CrowdStrike uncovers new agentic AI campaigns*. Vendor report. Blog.

[181] Insurance Journal (27 October 2026), on Moody's Ratings research on remediation of known exploited vulnerabilities. Article.

[182] Central Bank of Trinidad and Tobago, website posts and published files, 15-29 October 2026 (read 29 October 2026 from the site's public listing). Website.

Currency amounts are as published. Conclusions, ratings and scenarios are the report's analysis. They are not statements by the Central Bank of Trinidad and Tobago, TT-CSIRT, any bank or any other institution.